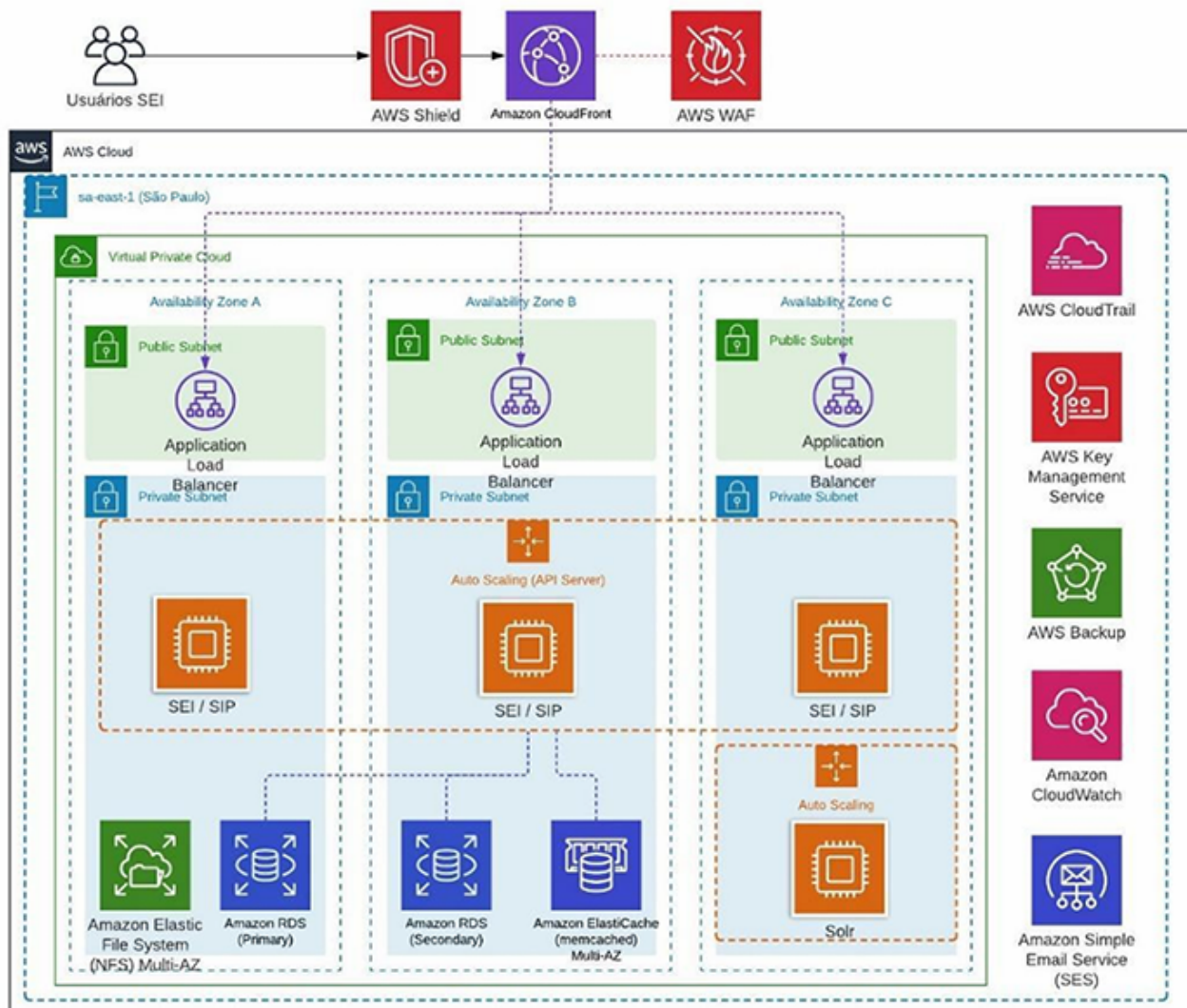


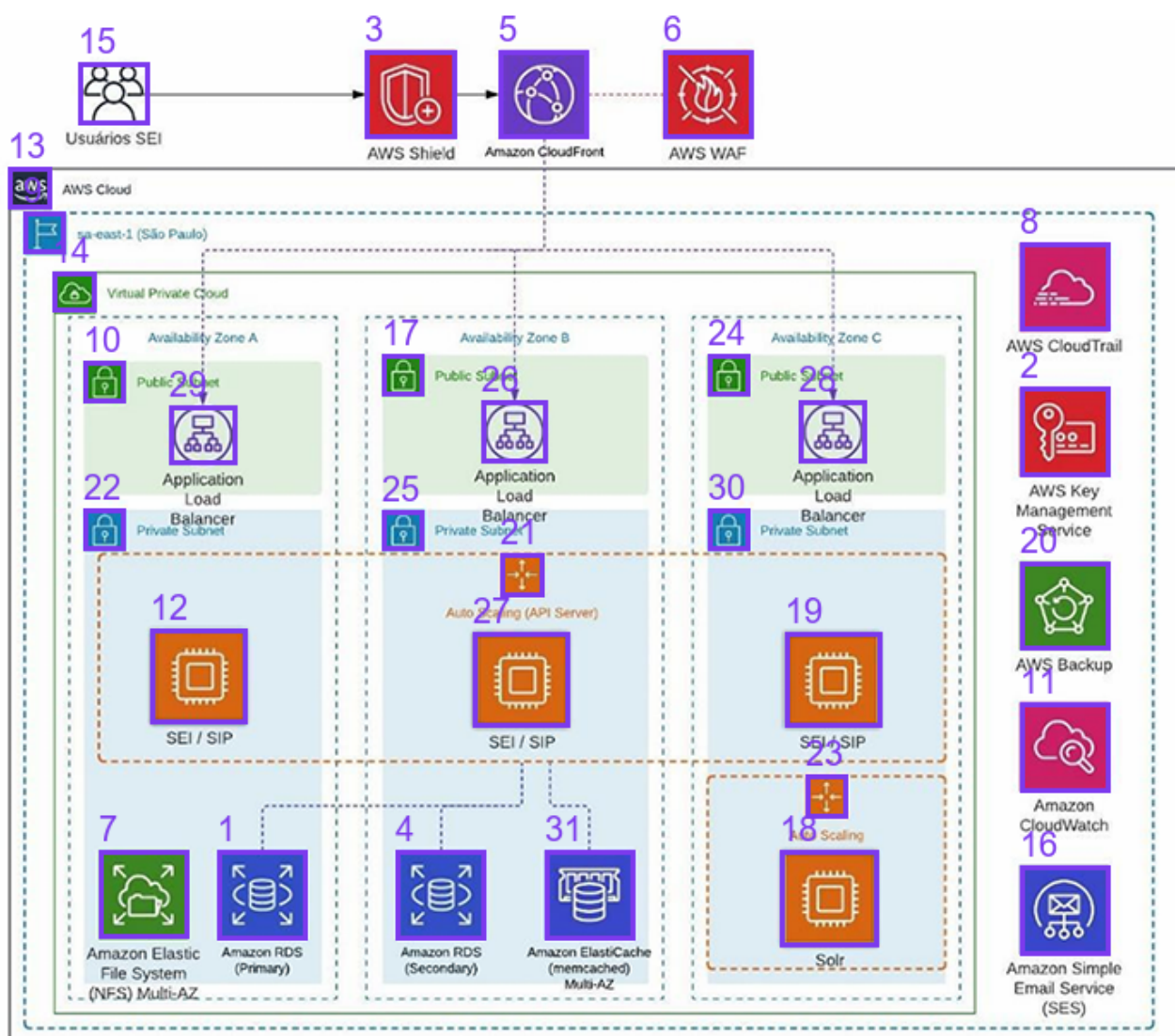
Gerado em: 2025-09-28 23:12:13

Figura 1 — Diagrama original



Gerado em: 2025-09-28 23:12:13

Figura 2 — Diagrama anotado (detecções)



- 1: Amazon RDS (0.99)
- 2: AWS Key Management Service (KMS) (0.98)
- 3: AWS Shield (0.98)
- 4: Amazon RDS (0.98)
- 5: Amazon CloudFront (0.98)
- 6: AWS WAF (0.97)
- 7: Amazon Elastic File System (EFS) (0.97)
- 8: AWS CloudTrail (0.96)
- 9: Região da AWS (0.96)
- 10: Sub-rede Pública da AWS (0.95)
- 11: Amazon CloudWatch (0.94)
- 12: Serviço de Computação AWS (EC2/Fargate) (0.94)
- 13: Logo da AWS Cloud (0.94)
- 14: VPC Privada da AWS (0.94)
- 15: Usuários da AWS (0.92)
- 16: Amazon SES (0.91)
- 17: Sub-rede Pública da AWS (0.91)
- 18: Serviço de Computação AWS (EC2/Fargate) (0.91)
- 19: Serviço de Computação AWS (EC2/Fargate) (0.90)

Gerado em: 2025-09-28 23:12:13

- 20: AWS Backup (0.89)
- 21: Grupo de Auto Scaling da AWS (0.88)
- 22: Sub-rede Privada da AWS (0.86)
- 23: Grupo de Auto Scaling da AWS (0.85)
- 24: Sub-rede Pública da AWS (0.84)
- 25: Sub-rede Privada da AWS (0.84)
- 26: Application Load Balancer (ALB) (0.81)
- 27: Serviço de Computação AWS (EC2/Fargate) (0.78)
- 28: Application Load Balancer (ALB) (0.73)
- 29: Application Load Balancer (ALB) (0.72)
- 30: Sub-rede Privada da AWS (0.68)
- 31: Amazon ElastiCache (0.63)

Gerado em: 2025-09-28 23:12:13

Amazon RDS

Análise STRIDE:

Spoofing

- Um usuário mal-intencionado tentando se autenticar no *endpoint* do banco de dados usando credenciais roubadas.
- Uma aplicação comprometida falsificando a identidade de um serviço confiável (ex: uma função de processamento de dados) para acessar a base de dados.
- Tentativas de assumir a identidade de outro usuário por meio de ataques *pass-the-hash* ou *pass-the-ticket*, se o RDS estiver integrado a serviços de diretório.
- Acesso não autorizado ao console de gerenciamento do RDS, permitindo que um invasor se passe por um administrador de serviço para modificar a instância.
- Violação/Adulteração
- Adulteração e alteração de dados sensíveis armazenados nas tabelas do banco de dados (ataques DML - Linguagem de Manipulação de Dados).
- Modificação não autorizada dos parâmetros de configuração da instância RDS (ex: alterar o *database engine* ou regras de acesso de rede).
- Adulteração dos *snapshots* e backups armazenados (se o acesso ao armazenamento subjacente não estiver restrito), comprometendo a integridade da recuperação.
- Injeção de comandos SQL maliciosos (*SQL injection*) que alteram a lógica da aplicação ou a estrutura da base.
- Alteração das regras de rede e dos grupos de segurança (*Security Groups*) que protegem a instância, permitindo acesso de fontes não confiáveis.

Repudiation

- Um usuário com privilégios elevados realizando alterações críticas na infraestrutura do RDS (ex: exclusão de instâncias ou alteração de *backups*) e negando a autoria da ação.
- Ausência de logs de auditoria detalhados (ex: Logs de Auditoria do RDS ou *CloudTrail* desativados), impedindo a rastreabilidade de acessos e comandos SQL.
- Utilização de contas genéricas ou compartilhadas (ex: `admin\_app`), o que impede a determinação do indivíduo ou serviço responsável por uma transação.
- Falta de assinaturas digitais ou carimbos de tempo confiáveis em ações críticas, permitindo que a origem de um comando destrutivo seja negada.
- Divulgação de Informação
- Exposição de informações sensíveis (dados pessoais identificáveis ou dados financeiros) devido à configuração inadequada dos grupos de segurança (*Security Groups* ou ACLs de Rede).
- Divulgação de dados em trânsito se a conexão entre a aplicação e o *endpoint* do banco de dados não utilizar criptografia, como a Segurança da Camada de Transporte (TLS).
- Configuração de armazenamento de banco de dados sem criptografia em repouso, tornando os dados legíveis em caso de acesso físico ou lógico ao armazenamento.
- Ataques de enumeração que exploram mensagens de erro de aplicação ou erros internos do banco de dados para mapear a estrutura do esquema.

Denial of Service

- Ataques de saturação de conexão (excesso de requisições de login) que esgotam o número máximo de conexões permitido pelo *database engine*.
- Execução de consultas maliciosamente complexas ou ineficientes que consomem 100% dos recursos de Unidade Central de Processamento (CPU) e memória da instância.
- Ataque Distribuído de Negação de Serviço (DDoS) visando o *endpoint* do banco de dados, caso ele esteja exposto publicamente.
- Esgotamento do espaço de armazenamento da instância (*storage full*), impedindo que a base de dados aceite novas transações de escrita.
- Falhas de configuração que levam ao estrangulamento de rede ou limitação excessiva de recursos para usuários legítimos.

Elevation of Privilege

Gerado em: 2025-09-28 23:12:13

- Exploração de vulnerabilidades não corrigidas no *software* do banco de dados subjacente (ex: falhas no kernel do PostgreSQL ou MySQL) para obter acesso de superusuário.
- Um usuário com privilégios limitados elevando seu nível de acesso explorando falhas de lógica em procedimentos armazenados.
- Comprometimento de uma conta de aplicação que possui privilégios excessivos (ex: permissão para executar comandos DDL - Linguagem de Definição de Dados), permitindo a criação de novas contas administrativas.
- Ataques de *buffer overflow* ou injeção de código que permitem ao invasor executar código arbitrário na máquina do banco de dados com privilégios de administrador.

Mitigações sugeridas:

Spoofing

- Implementar autenticação Multifator (MFA) obrigatória para todas as contas administrativas no Diretório Ativo do Azure (AAD).
- Utilizar Identidades Gerenciadas do Azure para que serviços e aplicações se autenticuem na base de dados, eliminando credenciais embutidas.
- Forçar a integração com o AAD para autenticação de usuários, evitando autenticação SQL local sempre que possível.
- Restringir o acesso ao console de gerenciamento (Portal do Azure ou comandos CLI) usando políticas de Acesso Condicional.
- Utilizar um Cofre de Chaves do Azure para armazenar quaisquer segredos ou *strings* de conexão que não possam usar identidades gerenciadas.
- Violação/Adulteração
- Aplicar o princípio do menor privilégio (PoLP) através do Controle de Acesso Baseado em Função (RBAC - *controle de acesso baseado em função (RBAC)*) no nível da base de dados e da assinatura.
- Utilizar um *Firewall* de Aplicação Web (WAF) do Azure para filtrar e bloquear tentativas de injeção SQL (*SQL injection*) antes que atinjam a aplicação.
- Proteger as configurações críticas da instância usando Bloqueios de Recurso do Azure (por exemplo, "Somente Leitura" ou "Não Excluir").
- Garantir que as políticas de Gerenciamento de Alterações exijam revisão por pares para modificações nos Grupos de Segurança de Rede (NSG).
- Implementar *Stored Procedures* (Procedimentos Armazenados) com parâmetros de entrada estritamente tipados para evitar comandos DML arbitrários.

Repudiation

- Ativar e configurar a Auditoria SQL do Azure para registrar todas as atividades de login, comandos DDL (Linguagem de Definição de Dados) e DML (Linguagem de Manipulação de Dados) críticas.
- Armazenar logs de auditoria em um Espaço de Trabalho do Log Analytics com retenção de longo prazo e acesso segregado.
- Exigir que cada usuário (humano ou serviço) utilize uma identidade exclusiva, proibindo o uso de contas genéricas ou compartilhadas.
- Utilizar o Azure Policy para garantir que a auditoria detalhada esteja ativada em todas as instâncias de banco de dados.
- Configurar Alertas do Azure monitorar para notificar imediatamente sobre a desativação ou alteração do serviço de auditoria.
- Divulgação de Informação
- Garantir que todas as instâncias de banco de dados do Azure utilizem criptografia transparente de dados (TDE), assegurando a criptografia em repouso.
- Forçar o uso de Segurança da Camada de Transporte (TLS - *Transport Layer Security*) 1.2 ou superior para todas as conexões em trânsito.
- Implementar segmentação de rede usando VNETs (Redes Virtuais do Azure) e *endpoints* privados, isolando a base de dados da internet pública.
- Configurar a aplicação para suprimir ou generalizar mensagens de erro detalhadas que revelem a estrutura interna do esquema.

Gerado em: 2025-09-28 23:12:13

- Usar a funcionalidade Always Encrypted do Azure SQL DB para proteger colunas de dados sensíveis dentro do banco de dados.

Denial of Service

- Monitorar e limitar as conexões de entrada na instância de banco de dados usando o *firewall* nativo do Azure ou os NSGs.
- Utilizar o dimensionamento automático ou recursos de alta disponibilidade do Azure, como Grupos de *Failover* Automático, para resiliência imediata.
- Empregar *Azure DDoS Protection Standard* no nível da Rede Virtual para proteção contra ataques volumétricos.
- Definir e monitorar limites de recursos de armazenamento (CPU, E/S e espaço) e configurar o alerta proativo para expansão automática.
- Revisar e otimizar regularmente as consultas de banco de dados de alto custo, utilizando o Query Performance Insight do Azure SQL.

Elevation of Privilege

- Garantir que as atualizações do sistema operacional e do *engine* do banco de dados sejam gerenciadas pelo Azure (modelo PaaS), mantendo o *software* corrigido.
- Separar as funções de administrador de plataforma (administrador do Azure) das funções de administrador de dados (DBA), aplicando separação de deveres.
- Auditar e remover quaisquer permissões de alto privilégio (como DDL) de contas de aplicação, mantendo-as estritamente limitadas a comandos DML.
- Utilizar o AAD para gerenciar o acesso just-in-time (JIT) para tarefas administrativas de alto risco.
- Analisar o código de procedimentos armazenados criticamente para evitar vulnerabilidades de lógica ou *buffer overflow*.

AWS Key Management Service (KMS)

Análise STRIDE:

Spoofing

- Um ator mal-intencionado tentando se passar por uma Identidade Gerenciada (Managed Identity) configurada no Microsoft Entra ID para solicitar operações de chave junto ao Azure Key Vault (AKV).
- Tentativas de ataques de *phishing* direcionados a administradores de cofre de chaves para obter credenciais ou *tokens* de acesso privilegiado.
- Comprometimento de uma Chave de Conta de Armazenamento (Storage Account Key) que possui permissões elevadas para leitura de segredos no AKV.
- Uso indevido de certificados expirados ou roubados para autenticação mútua (mTLS) em serviços que consomem chaves criptográficas.

Tampering

- Modificação não autorizada das políticas de acesso do Azure Key Vault, seja via listas de controle de acesso (ACLs) ou Controle de Acesso Baseado em Função do Azure (Azure RBAC), permitindo operações de chaves por entidades não confiáveis.
- Alteração dos atributos de uso da chave, como desativar ou agendar a expiração de uma Chave Gerada pelo Cliente (CMK) crítica, interrompendo operações de sistemas dependentes.
- Adulteração dos logs de atividades e de auditoria exportados do Key Vault para o Azure monitorar, ocultando a tentativa de exportação de material criptográfico.
- Modificação dos atributos de segurança de uma chave, como desabilitar o requisito de Módulo de Segurança de Hardware (HSM) para uma chave protegida por HSM.

Repudiation

- Um usuário ou serviço negando ter executado a exclusão, rotação ou desativação de uma chave crítica, se o registro de auditoria no Azure for insuficiente ou tiver sido limpo.
- Falha em registrar de forma imutável a mudança de proprietário ou de política de retenção para uma Chave Gerenciada pelo Cliente (CMK).

Gerado em: 2025-09-28 23:12:13

- Ausência de trilhas de auditoria detalhadas que associem explicitamente o *Service Principal* (Entidade de Serviço) ou a Identidade Gerenciada exata que realizou uma operação de descryptografia sensível.
- Não utilização do *Log Analytics* para garantir a retenção de longo prazo e a não alteração dos logs de acesso ao Azure Key Vault.
- Divulgação de Informação
- Vazamento de metadados das chaves, como política de rotação, data de criação ou *tags* (etiquetas), que podem ser usados para engenharia social ou ataques de reconhecimento.
- Exposição do material criptográfico da chave durante a comunicação se a conectividade com o Azure Key Vault não for forçada por TLS (Segurança da Camada de Transporte) 1.2 ou superior.
- Divulgação acidental de segredos ou certificados armazenados devido à configuração excessivamente permissiva das redes de acesso (*firewalls* ou Grupos de Segurança de Rede - NSGs).
- Ataques de canal lateral que extraem informações sobre a chave durante a operação de criptografia/descryptografia se o ambiente de execução não for isolado (aplicável a chaves que saem do HSM).

Denial of Service

- Saturação do ponto de extremidade (endpoint) do Azure Key Vault com um volume excessivo de solicitações de criptografia ou descryptografia, excedendo os limites de limitação de taxa (*throttle*), impedindo o acesso legítimo.
- Exclusão ou desativação de uma Chave Gerada pelo Cliente (CMK) essencial, resultando em interrupção total dos serviços dependentes, como Azure Storage ou Azure SQL.
- Um ataque de Negação Distribuída de Serviço (DDoS) que impede a conectividade de rede com a infraestrutura do Azure, bloqueando o acesso ao serviço de gerenciamento de chaves.
- Bloqueio do acesso ao AKV por meio da configuração incorreta ou intencional de *Azure Private Link* ou *Private Endpoints*, isolando aplicações legítimas de seus segredos.

Elevation of Privilege

- Um usuário que possui permissão de "leitura" ou "obtenção" de segredos obtendo, indevidamente, privilégios para "exportar" ou "excluir" o material da chave, explorando vulnerabilidades de política.
- Configuração incorreta de Definições de Função (Role Definitions) no Azure RBAC que permite a um operador de cofre de chaves atribuir a si mesmo o papel de administrador no cofre.
- Obtenção de acesso privilegiado a uma identidade de serviço (Service Principal) com permissão para modificar as políticas de acesso do próprio Key Vault.
- Exploração de falhas de lógica de negócio para converter acesso a metadados de chave em acesso ao material criptográfico da chave, ultrapassando os limites do HSM (Módulo de Segurança de Hardware).

Mitigações sugeridas:

Spoofing

- Exigir autenticação multifator (MFA) para todas as contas administrativas com acesso ao Azure Key Vault (AKV).
- Utilizar Identidades Gerenciadas (Identidade Gerenciada) para acesso de serviço a serviço no AKV, eliminando credenciais estáticas.
- Monitorar e auditar tentativas de acesso não autorizado por Identidades Gerenciadas não reconhecidas.
- Implementar políticas de Acesso Condicional no Microsoft Entra ID para restringir o acesso ao plano de controle do AKV.
- Garantir a rotação automatizada e a validação contínua de certificados usados para autenticação mútua (mTLS).

Tampering

- Aplicar bloqueios de recursos (bloqueios de recursos) de "Somente Leitura" ou "Não Excluir" em cofres de chaves críticos.
- Implementar Políticas do Azure (Azure Policy) para garantir que as políticas de acesso do AKV sigam o princípio do privilégio mínimo.
- Configurar a exportação de logs de auditoria do AKV para um *Log Analytics Workspace* com retenção imutável.
- Revisar e restringir rigorosamente quem possui a permissão de atribuição de função (*roleAssignments/write*) no escopo do AKV.
- Utilizar a Proteção de Purga (*Purge Protection*) para impedir a exclusão imediata e permanente de chaves protegidas por HSM.

Gerado em: 2025-09-28 23:12:13

Repudiation

- Configurar trilhas de auditoria detalhadas para registrar o ID exato da Entidade de Serviço (*Service Principal*) que realiza cada operação.
- Garantir que todos os logs de auditoria de operações do AKV sejam roteados para um armazenamento com retenção de longo prazo (mínimo 5 anos).
- Forçar a imutabilidade dos logs de auditoria e de diagnóstico usando Bloqueios de Retenção no Armazenamento do Azure.
- Monitorar e alertar sobre tentativas de limpar ou desabilitar o registro de log de diagnóstico do AKV.
- Divulgação de Informação
- Forçar o uso da versão mínima de TLS (Segurança da Camada de Transporte) 1.2 para todas as conexões de entrada ao AKV.
- Implementar *Azure Private Link* e *Private Endpoints* para garantir que o acesso ao AKV seja feito apenas via rede privada.
- Restringir o acesso aos metadados da chave (como *tags* e políticas de rotação) usando Controles de Acesso Baseado em Função (RBAC) específicos.
- Configurar o *firewall* do AKV para negar todo o tráfego público e permitir apenas sub-redes confiáveis.
- Garantir que chaves protegidas por HSM (Módulo de Segurança de Hardware) tenham o atributo "exportável" desabilitado.

Denial of Service

- Habilitar a proteção de exclusão suave (*Soft Delete*) e a Proteção de Purga (*Purge Protection*) para chaves essenciais.
- Implementar lógica de repetição (*retry logic*) nas aplicações para lidar graciosamente com a limitação de taxa (*throttle*) do AKV.
- Monitorar e escalar proativamente os limites de serviço do AKV se o volume de transações for consistentemente alto.
- Utilizar o Azure DDoS Protection (Proteção contra Negação Distribuída de Serviço) nas Redes Virtuais (VNet) que acessam o AKV.
- Garantir que as regras de rede de *Private Link* sejam revisadas regularmente para evitar bloqueios acidentais de aplicações legítimas.

Elevation of Privilege

- Aplicar o princípio de segregação de deveres, separando administradores de cofre de operadores de chave/secreto.
- Implementar o PIM (Gerenciamento de Identidade Privilegiada) do Entra ID para acesso *just-in-time* (JIT) a funções administrativas do AKV.
- Restringir a capacidade de criação e modificação de Definições de Função (Role Definitions) personalizadas no escopo do cofre.
- Usar o Azure RBAC para o plano de dados, garantindo que usuários com acesso de "obter" não possam "exportar" chaves.
- Auditar rigorosamente atribuições de função que permitam a uma identidade de serviço modificar as políticas de acesso do AKV.

AWS Shield

Análise STRIDE:

Spoofing

- Comprometimento de credenciais de automação (como *Service Principal* ou identidades gerenciadas) usadas para gerenciar as regras e o escopo da Proteção contra DDoS do Azure.

Tampering

- Representação
- O atacante forja pacotes de rede (Representação (Spoofing)) com metadados específicos para tentar contornar os algoritmos de detecção de assinatura do serviço de proteção da Azure.
- Alteração não autorizada dos limiares de mitigação de ataque (thresholds), tornando o serviço menos sensível a ataques volumétricos ou de esgotamento de estado.

Gerado em: 2025-09-28 23:12:13

- Modificação das políticas de filtragem ou das listas de negação (blocklists) associadas, permitindo que tráfego malicioso conhecido passe despercebido.
- Injeção de comandos maliciosos através da interface de linha de comando (C-L-I) ou A-P-I para desabilitar o monitoramento ou alterar o escopo da Rede Virtual (V-Net) protegida.
- Adulteração dos dados de logs e métricas de ataque armazenados no *Azure monitorar*, dificultando a análise forense pós-incidente.

Repudiation

- Um administrador nega ter desativado ou alterado o nível de serviço (ex.: de Standard para Basic) da proteção DDoS, devido à ausência ou manipulação dos logs de auditoria imutáveis.
- Falta de logs detalhados e específicos que comprovem o momento exato e o tipo de mitigação aplicada pelo sistema em resposta a um vetor de ataque particular.
- Um processo de automação (ex.: uma função *serverless*) realiza uma mudança crítica nas regras de proteção sem um rastreamento claro da identidade humana que acionou a automação.
- A plataforma não consegue provar que a telemetria reportada sobre o ataque (volume, duração, I-P de origem) é autêntica e não foi modificada por um atacante.

Information Disclosure

- Acesso não autorizado a logs e relatórios de métricas do *Azure monitorar*, que podem revelar padrões detalhados de tráfego, endereços I-P de infraestrutura interna ou a topologia da aplicação protegida.
- Vazamento de informações de configuração da rede (ex.: sub-redes, regras de *Network Security Group* - N-S-G) que são inferidas a partir da análise das políticas de mitigação.
- Exposição acidental de dados de telemetria sensíveis do cliente a terceiros devido a configurações incorretas de compartilhamento de logs (ex.: para soluções de gerenciamento de eventos e informações de segurança - S-I-E-M).

Denial of Service

- Um agente malicioso tenta se passar por um administrador de assinatura para desativar as políticas de proteção contra negação de serviço distribuída (DDoS) via portal ou interface de programação de aplicações (A-P-I).
- Ataques de saturação de Camada 7 (ex.: *HTTP Flood*) que não são totalmente mitigados pelo serviço de proteção de Camada 3/4 e sobrecarregam os recursos de aplicação (necessitando de soluções como *Azure Front Door* ou *WAF (Firewall de Aplicação Web)* - W-A-F complementares).
- Um ataque volumétrico maciço que, apesar da mitigação, consome recursos de computação ou esgota as conexões disponíveis (state exhaustion) na infraestrutura de rede da própria aplicação.
- Configuração excessivamente agressiva das regras de mitigação, resultando em Falsos Positivos que bloqueiam tráfego legítimo de usuários (indisponibilidade do serviço).
- Falha no plano de controle da Azure que impede a ativação, desativação ou a escalabilidade das políticas de proteção durante um incidente ativo.

Elevation of Privilege

- Tentativa de exploração de falhas na delegação de controle de acesso baseado em função (R-B-A-C - *controle de acesso baseado em função (RBAC)*) para atuar como um usuário com privilégios mais elevados no gerenciamento do recurso.
- Um usuário com permissões mínimas (ex.: leitor de métricas) explora uma falha de autorização na A-P-I da Azure para obter permissões de escrita e modificar as regras de mitigação.
- Comprometimento de um recurso com uma identidade gerenciada (Managed Identity) configurada com permissões excessivamente amplas (ex.: *Contributor* em toda a V-Net) sobre os recursos protegidos.
- Um atacante explora uma vulnerabilidade na infraestrutura do serviço de proteção para obter acesso ao contexto de execução da plataforma de nuvem subjacente (não apenas ao recurso do cliente).

Mitigações sugeridas:

Spoofing

- Implementar autenticação multifator (MFA) obrigatória para todos os administradores com acesso ao plano de controle da Azure.
- Utilizar identidades gerenciadas atribuídas pelo sistema (System-Assigned Identidade Gerenciada) em vez de *Service Principal* (Entidades de Serviço) para tarefas de automação.

Gerado em: 2025-09-28 23:12:13

Tampering

- Representação
- Configurar **Azure Policy** para auditar e restringir o uso de funções com amplos privilégios de gerenciamento de rede.
- Restringir o acesso ao plano de gerenciamento da Azure utilizando Acesso Condicional baseado em localização e dispositivos confiáveis.
- Habilitar logs de diagnóstico para o **Azure Activity Log** para rastrear a origem de todas as alterações de configuração.
- Implementar **Azure bloqueios de recursos** (Bloqueios de Recurso) para evitar a exclusão ou modificação não autorizada das políticas de proteção.
- Utilizar o **Log Analytics** para exportar logs de auditoria e métricas para um **Storage Account** configurado com imutabilidade (WORM - **Write Once, Read Many**).
- Configurar alertas de segurança no **Azure monitorar** para notificar a equipe sobre qualquer alteração nos limiares de mitigação de DDoS.
- Exigir fluxos de trabalho de Gerenciamento de Identidade Privilegiada (P-I-M) para aprovar temporariamente alterações em recursos críticos.
- Impor a separação de deveres (SoD) no R-B-A-C para que quem gerencia identidades não possa gerenciar configurações de mitigação.
- Configurar **Azure Policy** para impedir que comandos de **A-P-I** (Interface de Programação de Aplicações) desabilitem o monitoramento de forma abrupta.

Repudiation

- Garantir a retenção de longo prazo dos logs de auditoria no **Log Analytics** ou soluções de gerenciamento de eventos e informações de segurança (S-I-E-M) integradas.
- Assegurar que todos os eventos do plano de controle sejam registrados no **Azure Activity Log**, incluindo o **User Principal Name** ou o I-D da identidade automatizada.
- Configurar logs de diagnóstico do serviço de Proteção contra Negação de Serviço Distribuída (DDoS) para registrar detalhadamente o início e o fim de cada mitigação.
- Forçar a atribuição de identidades gerenciadas exclusivas para cada função de automação crítica, rastreando a origem da mudança no **Activity Log**.
- Utilizar a função de integridade de log do Azure monitorar para provar que a telemetria não foi adulterada após a ingestão.

Information Disclosure

- Restringir o acesso a **Azure monitorar** e aos **Log Analytics Workspaces** que contêm métricas de ataque apenas a funções de segurança e operação.
- Criptografar dados de logs em repouso nos **Storage Accounts** de arquivamento utilizando Chaves Gerenciadas pelo Cliente (C-M-K).
- Aplicar R-B-A-C detalhado para impedir que usuários de visualização de métricas de DDoS acessem a configuração subjacente da Rede Virtual (V-Net).
- Mascaram ou anonimizar endereços I-P internos e detalhes de infraestrutura antes de exportar logs para terceiros (S-I-E-M).
- Revisar as configurações de diagnóstico para garantir que apenas dados de ataque (e não dados confidenciais do cliente) sejam compartilhados com sistemas externos.

Denial of Service

- Implementar o **Azure Front Door** ou **Azure Application Gateway** com **WAF (Firewall de Aplicação Web)** (W-A-F) para mitigação de ataques de Camada 7 (ex.: **HTTP Flood**).
- Ajustar os limiares de mitigação de DDoS de acordo com a linha de base do tráfego legítimo da aplicação para evitar Falsos Positivos.
- Monitorar as métricas de utilização de recursos (CPU, memória) e esgotamento de conexões (**state exhaustion**) dos recursos protegidos.
- Configurar o dimensionamento automático horizontal dos recursos de aplicação (ex.: **Azure Virtual Machine Scale Sets**) em resposta a ataques.
- Garantir a redundância geográfica e alta disponibilidade dos recursos de rede implantando em múltiplas zonas de disponibilidade da Azure.

Elevation of Privilege

Gerado em: 2025-09-28 23:12:13

- Aplicar o princípio do menor privilégio (*menor privilégio*) ao configurar atribuições de Controle de Acesso Baseado em Função (R-B-A-C - *controle de acesso baseado em função (RBAC)*).
- Impor o uso de Gerenciamento de Identidade Privilegiada (P-I-M) para exigir ativação just-in-time para funções de gerenciamento de DDoS.
- Limitar o escopo das identidades gerenciadas (Identidade Gerenciada) estritamente aos recursos de rede que elas devem configurar, não a toda a V-Net.
- Realizar auditorias regulares de R-B-A-C e remover atribuições de funções de alto privilégio (ex.: *Contributor*) desnecessárias.
- Utilizar funções personalizadas de R-B-A-C da Azure com permissões mínimas, em vez de funções internas amplas.
- Monitorar e alertar no *Azure Activity Log* sobre tentativas de acesso a A-P-I que excedam as permissões atribuídas.

Amazon CloudFront

Análise STRIDE:

Spoofing

- Um agente malicioso pode tentar forjar o endereço do servidor de origem para que o CloudFront armazene em cache conteúdo comprometido.
- Comprometimento das chaves secretas utilizadas para autenticar a comunicação entre o CloudFront e a Origem Personalizada (Custom Origin), permitindo que um atacante se passe pela infraestrutura de entrega de conteúdo.
- Uso de certificados TLS (Segurança da Camada de Transporte) falsificados ou expirados para enganar os clientes finais sobre a legitimidade da conexão de borda.
- Ataques que visam a falsificação do protocolo de internet (IP) na camada de borda para direcionar usuários a um nó de cache (Edge Location) não autorizado ou malicioso.
- Violação/Adulteração
- Manipulação de parâmetros de requisição assinada (Signed URLs ou Signed Cookies) para permitir o acesso a recursos restritos sem autorização.
- Adulteração do cabeçalho de Host usado para rotear a requisição no CloudFront, resultando no direcionamento para uma origem não autorizada pelo administrador.
- Exploração de vulnerabilidades na comunicação entre o CloudFront e a origem para injetar código malicioso no conteúdo antes que ele seja armazenado no cache.
- Manipulação dos cabeçalhos de controle de cache ('Cache Control headers') para forçar o armazenamento ou a invalidação prematura de conteúdo, prejudicando a integridade dos dados servidos.

Repudiation

- Falha em registrar ou auditar de maneira robusta as alterações críticas nas configurações de Distribuição (Distribution Settings) do CloudFront, permitindo que administradores neguem responsabilidade por configurações inseguras.
- Desativação ou manipulação intencional dos registros de acesso (Access Logs) gerados na camada de borda, obscurecendo o rastro de atividades e dificultando a auditoria forense.
- Falta de rastreabilidade detalhada de eventos de bloqueio ou limitação de taxa (limitação de taxa) aplicados pelo serviço de Firewall de Aplicação Web (WAF) associado, impedindo a identificação precisa do agressor.
- Divulgação de Informação
- Armazenamento indevido de dados sensíveis, como informações de sessão ou cabeçalhos de autorização, no cache público devido a configurações inadequadas de chaves de cache (Cache Keys).
- Exposição de informações de versão do servidor de origem ou detalhes internos de erros (error messages) ao cliente final através do serviço de borda.
- Vazamento de dados por meio de requisições maliciosas que exploram a forma como o CloudFront lida com diferentes parâmetros de cache (ataques de *Cache Poisoning*).
- Configuração incorreta que permite a listagem de diretórios (Directory Listing) da origem, expondo a estrutura interna de arquivos aos usuários.

Denial of Service

- Ataques de Negação Distribuída de Serviço (DDoS) volumétricos visando sobrecarregar os nós de borda ou esgotar a capacidade de processamento de requisições.

Gerado em: 2025-09-28 23:12:13

- Sobrecarga do servidor de origem através de ataques de *Cache Busting*, onde o atacante envia requisições únicas a cada vez, forçando o CloudFront a revalidar o conteúdo repetidamente.
- Criação de custos excessivos para o operador da distribuição ao forçar invalidações de cache constantes ou altas taxas de transferência de dados para a origem.
- Exploração de falhas na lógica de limitação de taxa (limitação de taxa) ou no Firewall de Aplicação Web (WAF) para drenar recursos da distribuição.

Elevation of Privilege

- Exploração de falhas na gestão de identidade e acesso (IAM) para modificar as políticas de distribuição do CloudFront, permitindo que um usuário de baixo privilégio altere origens ou regras de acesso.
- Comprometimento de chaves de par (Key Pair) do CloudFront usadas para criar URLs assinadas (Signed URLs), permitindo que um invasor gere acesso privilegiado a conteúdo restrito.
- Uso indevido de permissões delegadas para acessar as configurações de integração com o serviço de Firewall de Aplicação Web (WAF) e desativar regras de segurança críticas.
- Elevação de privilégio através do acesso a funções de gerência do serviço (Service Control Plane), permitindo a deleção ou reconfiguração total da distribuição.

Mitigações sugeridas:

Spoofing

- Usar o Serviço de Ponto de Extremidade Privado (Private Endpoint Service) ou o Azure Front Door (AFD) para restringir o acesso à origem.
- Implementar o Identificador de Serviço de Borda (Service Tag) `AzureFrontDoor.backend` para aceitar tráfego apenas do AFD.
- Forçar o uso de TLS (Segurança da Camada de Transporte) de ponta a ponta com certificados válidos e geridos pelo Azure Key Vault.
- Utilizar Identidade Gerenciada (Managed Identity) para autenticar a comunicação entre o AFD e a origem de forma segura.
- Aplicar o protocolo HSTS (política de transporte estrito) (HSTS) para garantir que os clientes sempre usem conexões seguras.
- Violação/Adulteração
- Configurar regras de filtragem para impedir ataques de manipulação de cabeçalho *Host* no Azure WAF.
- Validar rigorosamente a integridade e a expiração dos Tokens de Segurança de Acesso do Azure CDN antes de conceder acesso.
- Implementar políticas de Segurança de Conteúdo (CSP) no aplicativo de origem para mitigar a injeção de código malicioso.
- Restringir quais cabeçalhos de controle de cache (`Cache Control headers`) o cliente pode enviar e o AFD pode processar.
- Assegurar a sanitização de todas as entradas de usuário e o uso de chamadas parametrizadas na aplicação de origem.

Repudiation

- Habilitar o registro detalhado de logs de acesso e diagnóstico do Azure Front Door e WAF.
- Centralizar logs de acesso do AFD/CDN no Azure monitorar (Log Analytics Workspace) com retenção estendida.
- Exigir a Autenticação Multifator (MFA) para todas as contas administrativas que modificam as configurações do serviço.
- Utilizar o Azure Policy para impor o registro de auditoria em alterações críticas de distribuição.
- Implementar RBAC (Controle de Acesso Baseado em Função) para garantir rastreabilidade nas modificações de configuração.
- Divulgação de Informação
- Excluir cabeçalhos sensíveis, como `Authorization` ou `Cookie`, das chaves de cache (Cache Keys) do AFD/CDN.
- Configurar páginas de erro personalizadas no AFD/CDN para mascarar detalhes internos e versões do servidor de origem.
- Usar expressões regulares no WAF para bloquear requisições que buscam listar diretórios ou arquivos de sistema.
- Garantir que a aplicação de origem desabilite a listagem de diretórios (*Directory Browsing*) em seu servidor web.
- Revisar e restringir as políticas de Cache Key para que apenas parâmetros necessários sejam incluídos, prevenindo *Cache Poisoning*.

Gerado em: 2025-09-28 23:12:13

Denial of Service

- Utilizar o Azure DDoS Protection Standard na VNet que hospeda a origem para mitigar ataques volumétricos.
- Implementar limites de taxa (*limitação de taxa*) agressivos no Azure Front Door WAF para mitigar sobrecarga de requisições.
- Configurar o AFD para ignorar ou padronizar *query strings* (strings de consulta) irrelevantes para mitigar *Cache Busting*.
- Otimizar as políticas de tempo de vida (TTL) do cache para manter os recursos na borda por mais tempo e reduzir a carga na origem.
- Implementar regras de filtragem geográfica ou baseada em IP no WAF para bloquear fontes de ataque conhecidas.

Elevation of Privilege

- Impor o RBAC (Controle de Acesso Baseado em Função) e o princípio do menor privilégio na gestão do Azure Front Door/CDN.
- Utilizar chaves de assinatura (Key Pairs) com rotação regular para Tokens de Segurança de Acesso (Signed URLs).
- Monitorar e auditar permissões de Identidade Gerenciada (Managed Identity) usadas por serviços de borda para acesso à origem.
- Aplicar Políticas de Acesso Condicional do Microsoft Entra ID para proteger o plano de controle de recursos.
- Restringir as permissões de acesso às configurações do Firewall de Aplicação Web (WAF) a papéis altamente restritos.

AWS WAF

Análise STRIDE:

Spoofing

- Falsificação de Identidade (Representação (Spoofing))
- Logs do WAF que não incluem dados suficientes sobre a identidade do usuário (se autenticado) ou a *payload* exata da requisição, dificultando a análise forense.

Tampering

- Ataques que se passam pelo endereço IP legítimo de origem (cliente) para burlar listas de permissão configuradas no Firewall de Aplicação Web (WAF).
- Comprometimento do certificado TLS (Segurança da Camada de Transporte) configurado no Application Gateway ou Azure Front Door, permitindo que um invasor se passe pelo ponto de entrada legítimo do serviço.
- Uso de *proxies* ou túneis para mascarar a verdadeira origem geográfica ou de rede do tráfego malicioso, dificultando a aplicação de regras baseadas em localização.
- Tentativas de manipular cabeçalhos de encaminhamento (ex.: `X-Forwarded-For`) para que o WAF registre uma origem de cliente falsa.
- Violação de Dados (Violação de Integridade (Tampering))
- Codificação sofisticada da *payload* (carga útil) de ataque (ex.: SQL Injection ou Cross-Site Scripting) para evitar a detecção pelo Conjunto de Regras Gerenciado (CRS) do WAF.
- Fragmentação de requisições HTTP de forma que o WAF inspecione apenas partes da carga útil, permitindo que o restante dos dados modificados chegue ao servidor *backend*.
- Manipulação de campos de formulário ou parâmetros da URL após a inspeção inicial, explorando falhas de *caching* ou processamento assíncrono.
- Modificação de cookies ou variáveis de sessão criptografadas para alterar dados de estado que o WAF não está configurado para inspecionar.

Repudiation

- Falha na configuração de Logs de Diagnóstico do Azure monitorar, impedindo a auditoria completa de quais requisições foram bloqueadas ou permitidas pelo WAF.
- Ausência de logs de auditoria sobre as alterações nas políticas de WAF (criação, edição ou exclusão de regras personalizadas) dentro do portal Azure.

Information Disclosure

- Retorno de mensagens de erro HTTP detalhadas pelo WAF ou pelo Application Gateway que expõem informações sobre a infraestrutura de *backend* (versões de software, nomes de servidores ou IPs internos).

Gerado em: 2025-09-28 23:12:13

- Vazamento do endereço IP do servidor de origem da aplicação quando o WAF é ignorado por rotas de rede incorretamente configuradas ou acesso direto ao *backend*.
- Exposição accidental de informações sensíveis (como chaves de API em cabeçalhos) devido a regras de inspeção de resposta mal configuradas.
- Divulgação de informações sobre a política interna de segurança do WAF quando ele retorna erros que indicam exatamente qual regra (ID da regra CRS) foi violada.

Denial of Service

- Negação de Ação (Repúdio)
- Desativação intencional ou não documentada de regras críticas do WAF por um administrador malicioso, permitindo um ataque e subsequentemente negando a responsabilidade.
- Ataques de Negação de Serviço Distribuída (DDoS) que sobrecarregam a capacidade de processamento das instâncias do Application Gateway ou Front Door que hospedam o WAF, mesmo com a proteção DDoS do Azure ativada.
- Exploração de regras de inspeção que utilizam expressões regulares complexas e ineficientes, levando o WAF a consumir excessivamente a CPU (Regex *Negação de Serviço* - ReDoS).
- Ataques baseados em volume de requisições (Layer 7) que, embora inspecionadas, exauzem o limite de requisições por segundo configurado para o WAF, degradando o serviço para usuários legítimos.
- Ataques que enviam requisições de corpo muito grande (upload de arquivos) que forçam o WAF a realizar uma inspeção demorada, esgotando recursos.

Elevation of Privilege

- Comprometimento de credenciais de contas do Azure que possuem permissão de Controle de Acesso Baseado em Função (RBAC) para modificar as políticas do WAF, permitindo a desativação completa das proteções.
- Exploração de uma vulnerabilidade na própria implementação do WAF (no Application Gateway ou Front Door) que permita a execução de comandos com privilégios elevados no ambiente de hospedagem.
- Uso da posição intermediária do WAF para injetar *tokens* ou cabeçalhos de autorização que são confiáveis pelo *backend*, resultando em elevação de privilégio na aplicação alvo.

Mitigações sugeridas:

Spoofing

- Force a Criptografia de Ponta a Ponta (End-to-End TLS - Segurança da Camada de Transporte) no Application Gateway, desabilitando o rebaixamento de protocolo.
- configurar o uso de Certificados Gerenciados (Managed Certificates) pelo Azure para Application Gateway ou Azure Front Door, simplificando a rotação e o controle de acesso.
- Implemente o Azure Front Door para garantir que o tráfego passe pela borda legítima e utilize a Proteção de Domínio (Domain Protection).
- Utilize o Firewall de Aplicação Web (WAF) do Azure para inspecionar e validar cabeçalhos `X-Forwarded-For`, rejeitando valores internos ou múltiplos.
- configurar Grupos de Segurança de Rede (NSGs) para restringir o acesso direto aos IPs dos servidores de *backend*, permitindo apenas o tráfego do Application Gateway/Front Door.
- Violação de Dados
- Mantenha o Conjunto de Regras Gerenciado (CRS - Core Rule Set) do WAF atualizado para detectar novas técnicas de codificação e ofuscação de *payload*.
- Ative a inspeção de corpo de requisição (*request body inspection*) no WAF, configurando limites estritos de tamanho de *payload* (carga útil).
- Utilize regras personalizadas no WAF para impor a validação estrita (allow-list) de todos os parâmetros de URL e campos de formulário esperados.
- configurar o WAF para inspecionar e descriptar (se aplicável) cookies e variáveis de sessão que contenham dados críticos de estado da aplicação.
- Utilize o recurso de Descodificação de URL e *Normalização* (Normalization) do WAF antes que o Conjunto de Regras Gerenciado (CRS) realize a inspeção.
- Negação de Ação

Gerado em: 2025-09-28 23:12:14

- Habilite a coleta de Logs de Diagnóstico do Azure monitorar para o WAF, roteando-os para um espaço de trabalho do Log Analytics para retenção obrigatória.
- Implemente Controle de Acesso Baseado em Função (RBAC) restritivo para as contas que podem modificar ou desativar as políticas do WAF.
- configurar Alertas do Azure monitorar sobre alterações nas Políticas de WAF (criação, modificação ou exclusão de regras personalizadas).
- Garanta que os logs do WAF incluam o IP de origem, a ID da regra acionada, e a *payload* exata da requisição para análise forense.
- Utilize o Azure Policy para garantir a conformidade obrigatória dos Logs de Diagnóstico para todos os recursos de WAF implantados.

Information Disclosure

- configurar páginas de erro personalizadas no WAF para retornar respostas genéricas (ex.: 403 Proibido) sem detalhes do servidor ou ID da regra.
- Utilize Redes Virtuais (VNETs) e Grupos de Segurança de Rede (NSGs) para impedir que o endereço IP do servidor de origem seja acessível de fora da rede.
- Remova ou sanitize cabeçalhos de resposta HTTP que exponham informações (ex.: `Server`, `X-Powered-By`) usando regras de reescrita de cabeçalho.
- Implemente o Key Vault do Azure para armazenar chaves de API e segredos, evitando sua exposição em cabeçalhos ou mensagens de erro.
- Valide que a política de WAF não retorna a ID da regra do Conjunto de Regras Gerenciado (CRS) quando uma requisição é bloqueada.

Denial of Service

- configurar e utilize o Plano de Proteção de Negação de Serviço Distribuída (DDoS Protection Plan) do Azure para recursos críticos.
- Aplique Limitação de Taxa (limitação de taxa) no WAF para limitar o número de requisições por segundo por IP de origem.
- Revise e teste a eficiência das expressões regulares em regras personalizadas para evitar Ataques de Negação de Serviço baseados em Expressões Regulares (ReDoS).
- configurar limites estritos de tamanho máximo de corpo de requisição (Max Request Body Size) no WAF para abortar uploads excessivamente grandes.
- Utilize a capacidade de dimensionamento automático (Autoscale) do Application Gateway para garantir resiliência e capacidade de absorver picos de tráfego.

Elevation of Privilege

- Implemente Autenticação Multifator (MFA) obrigatória para todas as contas administrativas com permissões de Controle de Acesso Baseado em Função (RBAC).
- Adote o Princípio do Mínimo Privilégio no Azure (RBAC), concedendo apenas as permissões necessárias para gerenciar o WAF.
- Monitore logs de auditoria do Azure (Azure Activity Logs) para detectar alterações não autorizadas em permissões ou políticas de WAF.
- configurar o WAF para remover quaisquer cabeçalhos de autorização ou *tokens* internos que possam ser injetados e confiados indevidamente pelo *backend*.
- Utilize o Azure Security Center (Defender for Cloud) para monitorar e gerenciar a postura de segurança dos serviços que hospedam o WAF.

Amazon Elastic File System (EFS)

Análise STRIDE:

Spoofing

- Tentativa de falsificação de credenciais de montagem para se passar por uma Máquina Virtual do Azure acessando o ponto de montagem do sistema de arquivos.

Gerado em: 2025-09-28 23:12:14

- Comprometimento de um Principal de Serviço do Azure (Service Principal) com permissões de acesso ao sistema de arquivos.
- Falsificação de identidade em conexões VPN ou ExpressRoute que interligam o ambiente do cliente (local ou outras Redes Virtuais do Azure) ao ponto de acesso do armazenamento.
- Uso de uma identidade comprometida no serviço de Diretório Ativo do Azure (Microsoft Entra ID) que possui um mapeamento de função de alto privilégio no gerenciamento do sistema de arquivos.
- Violação/Adulteração
- Modificação não autorizada de dados de arquivos críticos através de um ponto de montagem exposto ou configurado com permissões excessivas.
- Violação da política de ciclo de vida (lifecycle policy) do sistema de arquivos, resultando na exclusão ou movimentação não intencional de dados.
- Alteração das permissões de acesso (políticas NFS ou políticas de identidade IAM) configuradas no sistema de arquivos, permitindo acesso mais amplo a entidades não autorizadas.
- Adulteração dos metadados do sistema de arquivos para esconder atividades maliciosas ou dificultar a auditoria, como a modificação de datas e horas de criação.

Repudiation

- Um administrador nega ter modificado ou excluído pontos de acesso ou sistemas de arquivos críticos no painel de gerenciamento.
- Um cliente nega ter realizado operações de escrita ou exclusão em um arquivo, exigindo rastreamento detalhado via logs de auditoria do serviço.
- Desativação ou adulteração dos logs de acesso e operação do serviço, impedindo a determinação da origem de uma ação.
- Falha na correlação dos eventos de acesso do recurso de armazenamento com as identidades específicas do Diretório Ativo do Azure usadas para autenticação e autorização.
- Divulgação de Informação
- Acesso não autorizado a dados em repouso devido a configurações de política de acesso (IAM/NFS) excessivamente permissivas.
- Vazamento de dados durante a transferência (em trânsito) se a criptografia TLS (Transport Layer Security - Segurança da Camada de Transporte) ou Kerberos não for estritamente aplicada nos pontos de montagem.
- Configuração incorreta de Grupos de Segurança de Rede (NSG) do Azure, expondo o ponto de montagem do sistema de arquivos a faixas de IP ou sub-redes não confiáveis.
- Divulgação de metadados internos ou estruturais do sistema de arquivos que podem ser usados em ataques de reconhecimento e mapeamento de recursos.
- Falha na rotação regular das chaves de criptografia gerenciadas pelo cliente (CMK) utilizadas para proteger os dados em repouso.

Denial of Service

- Exaustão da capacidade de IOPS (Input/Output Operations Per Second) do sistema de arquivos através de um ataque volumétrico DDoS (Distributed Negação de Serviço - Negação de Serviço Distribuída) direcionado ao ponto de montagem.
- Atingir limites de taxa de transferência ou limites de objetos do sistema de arquivos através de operações massivas de escrita ou leitura, causando latência inaceitável para outros usuários.
- Esgotamento da capacidade de banda da conexão de rede privada (como ExpressRoute) que liga os recursos do Azure ao serviço, impedindo o acesso legítimo.
- Configuração de listas de controle de acesso (ACLs) que bloqueiam indevidamente o tráfego legítimo para o serviço de armazenamento.

Elevation of Privilege

- Exploração de vulnerabilidades no protocolo de acesso (NFS) para escalar de um usuário de rede com acesso limitado para acesso de nível *root* ao sistema de arquivos.
- Um usuário com permissão de somente leitura na política de acesso explora uma falha de configuração para obter permissões de escrita ou exclusão (DELETE).

Gerado em: 2025-09-28 23:12:14

- Comprometimento de uma conta de serviço de gerenciamento do Azure com permissões RBAC (controle de acesso baseado em função (RBAC) - Controle de Acesso Baseado em Função) para reconfigurar as políticas de acesso do sistema de arquivos.
- Engenharia reversa ou exploração de falhas em aplicativos que interagem com o armazenamento para executar código com privilégios elevados.

Mitigações sugeridas:

Spoofing

- Impor Autenticação Multifator (MFA) rigorosa para todas as identidades do Diretório Ativo do Azure (Microsoft Entra ID) com acesso administrativo.
- Utilizar Identidades Gerenciadas do Azure para Máquinas Virtuais (VMs), eliminando a necessidade de credenciais estáticas de montagem.
- Restringir as permissões de Principal de Serviço (Service Principal) estritamente ao princípio do menor privilégio na política IAM (Identity and Access Management - Gerenciamento de Identidade e Acesso).
- Implementar autenticação mútua (mutual authentication) e validação de certificados para conexões VPN e ExpressRoute que acessam o armazenamento.
- Utilizar o Acesso Condicional do Azure para exigir que as tentativas de montagem venham de dispositivos conformes e locais confiáveis.
- Violação/Adulteração
- Aplicar bloqueios de recursos (bloqueios de recursos) no Azure Resource Manager para prevenir a exclusão ou alteração de sistemas de arquivos e políticas críticas.
- Configurar a imutabilidade do armazenamento para dados de arquivos críticos, impedindo modificações por um período definido ou indefinido.
- Utilizar o controle de acesso baseado em função (RBAC - controle de acesso baseado em função (RBAC)) para garantir que apenas funções administrativas específicas possam modificar políticas de ciclo de vida.
- Monitorar ativamente e configurar alertas sobre qualquer alteração nas Listas de Controle de Acesso (ACLs) do NFS (Network File System) ou permissões IAM.
- Garantir que os logs de auditoria do plano de dados estejam protegidos contra adulteração por meio de retenção e imutabilidade no Azure monitorar.

Repudiation

- Habilitar e configurar o rastreamento detalhado de auditoria de plano de dados para todas as operações de leitura, escrita e exclusão no sistema de arquivos.
- Correlacionar logs de atividade do armazenamento com o Identificador Único do Usuário do Diretório Ativo do Azure (Microsoft Entra ID) que realizou a operação.
- Encaminhar os logs de gerenciamento do Azure (Activity Logs) e de operação para um Azure Sentinel ou Log Analytics Workspace com retenção legal.
- Impedir a desativação ou modificação das configurações de diagnóstico por meio de políticas do Azure (Azure Policies) e bloqueios de recursos.
- Revisar periodicamente os logs de auditoria de gerenciamento para rastrear quem modificou o acesso ou as configurações do sistema de arquivos no painel do Azure.
- Divulgação de Informação
- Aplicar o princípio do menor privilégio tanto nas atribuições de função RBAC quanto nas permissões NFS/IAM configuradas no sistema de arquivos.
- Exigir estritamente o uso de criptografia TLS (Transport Layer Security - Segurança da Camada de Transporte) ou Kerberos para todo o tráfego de dados em trânsito.
- Configurar Grupos de Segurança de Rede (NSG) do Azure para permitir o tráfego de montagem apenas de sub-redes e faixas de IP conhecidas e confiáveis.
- Utilizar criptografia de dados em repouso gerenciada pelo cliente (CMK - Customer Managed Key) e impor a rotação regular dessas chaves no Azure Key Vault.
- Restringir o acesso aos metadados e às APIs de gerenciamento do sistema de arquivos apenas a identidades com funções RBAC elevadas.

Denial of Service

Gerado em: 2025-09-28 23:12:14

- Monitorar o consumo de IOPS (Input/Output Operations Per Second) e taxa de transferência do sistema de arquivos e configurar o escalonamento proativo da capacidade.
- Implementar o Azure DDoS Protection Standard na Rede Virtual que hospeda o ponto de montagem para mitigar ataques volumétricos DDoS (Distributed Negação de Serviço - Negação de Serviço Distribuída).
- Utilizar políticas de qualidade de serviço (QoS) na conexão ExpressRoute para priorizar o tráfego essencial do sistema de arquivos.
- Configurar alertas no Azure monitorar para picos incomuns de utilização que possam indicar um ataque de negação de serviço.
- Revisar e testar as Listas de Controle de Acesso (ACLs) de rede e os NSGs para garantir que o tráfego legítimo não seja inadvertidamente bloqueado.

Elevation of Privilege

- Garantir que as máquinas virtuais clientes utilizem sistemas operacionais e bibliotecas atualizados para mitigar vulnerabilidades em protocolos de acesso como o NFS.
- Segregar estritamente as responsabilidades administrativas usando funções RBAC separadas para gerenciamento de rede, armazenamento e identidade.
- Implementar o gerenciamento de acesso privilegiado (PIM - Privileged Identity Management) para exigir justificativa e aprovação temporária para funções RBAC elevadas.
- Utilizar o princípio do menor privilégio para mapeamentos de usuários NFS, desativando o acesso de usuários *root* e de usuários anônimos.
- Realizar auditorias regulares das permissões de função RBAC aplicadas a Contas de Serviço do Azure para detectar atribuições excessivas.

AWS CloudTrail

Análise STRIDE:

Spoofing

- Um atacante compromete as credenciais de uma chave de acesso (Access Key) e se passa por uma entidade de serviço AWS legítima para executar ações.
- Incapacidade de correlacionar eventos de log com a identidade real de um usuário federado devido à falha na configuração correta dos atributos de identidade.
- Tentativas de falsificar a origem de uma chamada de API (Interface de Programação de Aplicativos) injetando metadados de identidade falsos nos cabeçalhos da solicitação.
- Vandalismo
- Modificação das políticas de gerenciamento de identidade e acesso (Identity and Access Management - IAM) que protegem a configuração da Trilha (Trail), permitindo que um usuário não autorizado altere quais eventos são registrados.
- Desativação da validação da integridade do arquivo de log, tornando impossível detectar se os logs armazenados foram alterados após a entrega.
- Alteração das permissões do *bucket* S3 de destino, permitindo a exclusão ou modificação dos logs brutos armazenados pelo CloudTrail.
- Substituição da chave de criptografia (Key Management Service - KMS) utilizada para proteger os logs por uma chave controlada pelo atacante.

Repudiation

- Um usuário com permissões elevadas desabilita ou deleta a Trilha do CloudTrail, impedindo a prova forense de suas ações posteriores.
- Configuração incorreta que falha ao registrar o endereço IP de origem ou o agente de usuário (*User Agent*) para determinadas chamadas de API, dificultando o rastreamento do executor.
- Falha em capturar eventos de gerenciamento críticos (Management Events) que documentam alterações na configuração da segurança da conta.
- Exclusão acidental ou intencional dos logs retidos devido a políticas de ciclo de vida do *bucket* S3 mal configuradas, perdendo o histórico de auditoria.
- Divulgação de Informação

Gerado em: 2025-09-28 23:12:14

- Armazenamento dos logs do CloudTrail em um *bucket* S3 sem criptografia adequada ou com políticas de acesso excessivamente permissivas (por exemplo, acesso público).
- Inclusão acidental de dados sensíveis (como segredos ou credenciais) nos parâmetros de solicitação da API, que são registrados em texto simples no log.
- Exposição de nomes de recursos, identificadores de usuário e mapeamentos de rede interna (IPs privados) contidos nos registros de eventos para entidades não autorizadas.
- Falha na implementação de criptografia em trânsito (Transport Layer Security - TLS, Protocolo de Segurança da Camada de Transporte) durante a entrega dos logs para sistemas externos de análise de segurança.

Denial of Service

- Um atacante satura o volume de chamadas de API na conta, potencialmente induzindo o estrangulamento (*limitação de taxa*) e fazendo com que o CloudTrail perca eventos legítimos durante picos de atividade.
- Bloqueio de acesso ao *bucket* S3 de logs através de listas de controle de acesso (Access Control Lists - ACLs) ou políticas de *bucket* restritivas, impedindo a ingestão de novos logs.
- Exclusão ou modificação da função de serviço (Service Role) do CloudTrail, negando-lhe a permissão de entregar os logs ao *bucket* S3 de destino.
- Ataque distribuído de negação de serviço (DDoS - Negação de Serviço Distribuída) direcionado aos endpoints da API, o que indiretamente afeta a capacidade do CloudTrail de registrar todas as atividades.

Elevation of Privilege

- Compromisso de uma entidade IAM que possui a permissão `cloudtrail:StopLogging` ou `cloudtrail:DeleteTrail`, permitindo que um atacante oculte suas trilhas de ataque.
- Configuração de uma Trilha de Organização que concede a um usuário de uma conta membro acesso de leitura a logs de contas com privilégios mais altos.
- Permissão de acesso irrestrito ao *bucket* S3 de logs para usuários que deveriam ter apenas a permissão para analisar o conteúdo, mas não para gerenciá-lo.
- Concessão da capacidade de modificar ou desabilitar seletores de eventos (Event Selectors) a um usuário de baixo privilégio, permitindo que ele limite o escopo da auditoria.

Mitigações sugeridas:

Spoofing

- Substituir o uso de chaves de acesso estáticas por Identidades Gerenciadas para serviços do Azure.
- Impor a autenticação multifator (MFA) para todos os usuários e entidades de serviço com acesso a recursos críticos.
- Aplicar políticas de Acesso Condicional do Entra ID para restringir o acesso a redes e dispositivos confiáveis.
- Utilizar o Entra ID para padronizar e gerenciar as identidades federadas, garantindo a correlação de logs.
- Configurar o Controle de Acesso Baseado em Função (RBAC) com o princípio do menor privilégio para todas as operações de API (Interface de Programação de Aplicativos).
- Vandalismo
- Impor Bloqueios de Recurso (bloqueios de recursos) de "Somente Leitura" ou "Não Excluir" nos recursos de armazenamento de logs e configurações de diagnóstico.
- Habilitar a imutabilidade (immutability) ou retenção baseada em tempo para os Blobs no Azure Storage onde os logs são persistidos.
- Restringir severamente o acesso de modificação às políticas de retenção e exportação de logs no Azure monitorar.
- Utilizar políticas do Azure para auditar e forçar a utilização de chaves gerenciadas pelo cliente (Customer Managed Keys) no Azure Key Vault.
- Monitorar ativamente e alertar sobre qualquer alteração nas configurações de exportação de logs ou nas políticas de acesso ao Azure Storage.

Repudiation

- Garantir que os logs de atividade do Azure (Activity Log) e os logs de auditoria do Entra ID sejam exportados e retidos de forma imutável.
- Implementar a retenção de logs de longo prazo (maior que 90 dias) no Azure monitorar Log Analytics.
- Utilizar o Azure Policy para impedir a desativação do registro de diagnóstico em recursos de alta criticidade.
- Configurar alertas em tempo real para tentativas de exclusão ou desabilitação de configurações de exportação de logs de auditoria.

Gerado em: 2025-09-28 23:12:14

- Assegurar que os logs de auditoria do Entra ID capturem metadados essenciais como endereço IP de origem e agente de usuário (*User Agent*).
- Divulgação de Informação
- Desabilitar o acesso público ao Azure Blob Storage e utilizar *endpoints* privados (Private Link) para a ingestão de logs.
- Impor a criptografia em repouso (Encryption at Rest) usando o Azure Key Vault para proteger os logs armazenados.
- Utilizar o Azure Policy para exigir que toda a comunicação de log seja feita via TLS (Protocolo de Segurança da Camada de Transporte) 1.2 ou superior.
- Revisar e implementar políticas de mascaramento de dados nos logs de aplicação para evitar a inclusão acidental de segredos.
- Restringir o acesso aos logs com Controle de Acesso Baseado em Função (RBAC) estrito, limitando-o apenas a funções de leitura (Reader Roles) essenciais.

Denial of Service

- Utilizar a Proteção Azure DDoS (Negação de Serviço Distribuída) para mitigar ataques volumétricos contra *endpoints* de aplicação.
- Configurar *endpoints* de serviço do Azure Storage com capacidade e taxa de ingestão otimizadas para evitar perdas de log.
- Implementar o monitoramento de limites de taxa de API para identificar e responder a picos de chamadas que possam causar estrangulamento (*limitação de taxa*).
- Garantir que a Identidade Gerenciada responsável pela exportação de logs mantenha apenas permissões de escrita, negando as de exclusão.
- Configurar alertas sobre a indisponibilidade ou latência de componentes chave do Azure monitorar e Log Analytics.

Elevation of Privilege

- Utilizar o Gerenciamento de Identidade Privilegiada (PIM) do Entra ID para exigir a ativação just-in-time (JIT) para funções administrativas.
- Separar as permissões de análise de logs (leitura) das permissões de gerenciamento de configurações de logs (escrita/exclusão).
- Remover permissões que permitam a desativação de diagnósticos (`/delete` ou `/write` em configurações de diagnóstico) de funções de baixo privilégio.
- Implementar políticas de RBAC que proíbam a atribuição de permissões de gerenciamento de Contas de Armazenamento a usuários não administradores.
- Aplicar o princípio do menor privilégio para identidades que atuam em contas membro de um Grupo de Gerenciamento do Azure.
- Auditar periodicamente as atribuições de função para identificar e remediar o excesso de privilégios (*overscoping*) nas assinaturas.

Região da AWS

Análise STRIDE:

Spoofing

- Representação (Spoofing) (Falsificação de Identidade)
- Ataques de *phishing* direcionados a credenciais de administradores de assinatura ou de usuários do Azure Active Directory (AAD).
- Comprometimento de chaves de Identidades Gerenciadas (Identidade Gerenciada) usadas por aplicativos para imitar um serviço legítimo dentro da Região.
- Falsificação de endereços IP de origem em Grupos de Segurança de Rede (NSGs) ou firewalls que confiam na identidade da rede.

Tampering

- Criação de Entidades de Serviço (Service Principal) fraudulentas com permissões excessivas dentro da Região do Azure.
- Violação de Integridade (Tampering) (Violação/Alteração de Dados)

Gerado em: 2025-09-28 23:12:14

- Modificação não autorizada de regras do Azure Policy que garantem a conformidade e a segurança dos recursos provisionados na Região.
- Alteração das regras de roteamento (por exemplo, tabelas de rotas definidas pelo usuário) em Redes Virtuais para redirecionar o tráfego a um destino malicioso.
- Mudança dos atributos de imutabilidade em contêineres de armazenamento, permitindo a exclusão ou alteração de registros críticos de auditoria.
- Modificação das configurações de Diagnóstico de Logs no Azure monitorar, impedindo a coleta de eventos de segurança.

Repudiation

- Falta de rastreabilidade completa das ações executadas por Identidades Gerenciadas ou Contas de Serviço (Service Principal) em recursos regionais.
- Configuração inadequada dos logs de auditoria (por exemplo, *Activity Logs* e *Diagnostic Settings*) que impede a vinculação de ações administrativas ao ator.
- Ausência de logs de fluxo (Flow Logs) para identificar qual máquina virtual ou interface de rede iniciou uma comunicação específica dentro da VNet.
- Falha em exigir e registrar assinaturas digitais ou confirmações para mudanças críticas de infraestrutura via Infraestrutura como Código (IaC).
- Divulgação de Informação (Divulgação de Informação)
- Exposição acidental de chaves secretas ou certificados armazenados no Azure Key Vault devido a políticas de acesso excessivamente permissivas.
- Configuração incorreta de *endpoints* de serviço no Armazenamento do Azure, expondo dados a IPs públicos ou não autorizados.
- Vazamento de Informação de Identificação Pessoal (PII) por meio de logs ou métricas do Azure monitorar que não foram devidamente anonimizados.
- Tráfego de dados não criptografado entre serviços dentro da mesma Região ou Zonas de Disponibilidade (sem o uso de TLS - Segurança da Camada de Transporte).
- Publicação de *templates* do Azure Resource Manager (ARM) que contêm informações sensíveis codificadas de forma insegura.

Information Disclosure

- Uso de *tokens* de acesso roubados ou expirados para acessar APIs de gerenciamento do Azure.
- Violação de dados em repouso no Armazenamento do Azure (Azure Storage) por meio do comprometimento das chaves de criptografia gerenciadas.

Denial of Service

- Ataques de DDoS (Negação de Serviço Distribuído) que sobrecarregam os serviços de infraestrutura regionais, como *Application Gateways* ou *Load Balancers*.
- Esgotamento das cotas de recursos da assinatura (por exemplo, IPs públicos, *gateways* de VNet ou instâncias de VM) por meio de provisionamento malicioso rápido.
- Saturação da capacidade da rede em Pontos de Extremidade Privados (*Private Endpoints*) usados para acessar serviços PaaS (Plataforma como Serviço) gerenciados pela Região.
- Criação de loops de rede ou exaustão de conexões em redes virtuais através de regras de NSG mal configuradas.

Elevation of Privilege

- Exploração de falhas de configuração de RBAC (Controle de Acesso Baseado em Função) que permitem a um usuário de baixo privilégio assumir uma função de proprietário (*Owner*) ou contribuinte (*Contributor*).
- Comprometimento de uma máquina virtual que tem permissões de acesso ao serviço de *host* ou a outros recursos fora do seu escopo de segurança.
- Abuso de permissões de delegação no Azure Active Directory que permitem a criação de novos usuários ou a atribuição de funções elevadas.
- Exploração de falhas em políticas de acesso condicional ou autenticação multifator (MFA) para obter acesso a contas de administrador.
- Uso de credenciais de contas de serviço com privilégios excessivos para manipular recursos em diferentes Grupos de Recursos dentro da Região.

Gerado em: 2025-09-28 23:12:14

Mitigações sugeridas:

Spoofing

- Falsificação de Identidade (Representação (Spoofing))
- Implementar Autenticação Multifator (MFA) obrigatória para todos os usuários privilegiados do Azure Active Directory (AAD).
- Usar Identidades Gerenciadas Atribuídas pelo Sistema (em vez de credenciais) para comunicação entre recursos PaaS.
- Aplicar o princípio do menor privilégio na atribuição de funções para Entidades de Serviço e Identidades Gerenciadas.
- Utilizar certificados de serviço de identidade de **workload**, ao invés de segredos, para Entidades de Serviço.
- Habilitar o Azure Defender for Identity para detectar ataques de **phishing** e uso de **tokens** roubados.
- Configurar **Azure Private Link** para que a identidade do recurso, e não o endereço IP de origem, seja o fator de confiança.

Tampering

- Violação/Alteração de Dados (Violação de Integridade (Tampering))
- Restringir a modificação de regras do Azure Policy a usuários específicos usando o Acesso Condicional do AAD.
- Aplicar bloqueios de recursos (bloqueios de recursos) em tabelas de rotas e Grupos de Segurança de Rede críticos.
- Utilizar o Azure Policy para garantir a coleta contínua e a integridade das configurações de Diagnóstico de Logs.
- Exigir revisões por pares e aprovação para alterações na infraestrutura implantada via **templates** ARM.

Repudiation

- Configurar a política de imutabilidade (WORM - Write Once Read Many) no Armazenamento de Blobs para logs de auditoria.
- Centralizar Logs de Atividade e Logs de Diagnóstico em um Workspace do Log Analytics com retenção de longo prazo.
- Exigir a habilitação de Logs de Fluxo (Flow Logs) para todos os Grupos de Segurança de Rede (NSGs) críticos na VNet.
- Garantir que todas as Identidades Gerenciadas usem nomes descritivos e rastreáveis vinculados a um aplicativo ou serviço.
- Utilizar o Azure monitorar para correlacionar eventos de plano de controle e plano de dados do recurso ao ator.
- Aplicar o Azure Policy para garantir que o Log de Atividade seja exportado de forma redundante para o Armazenamento ou Splunk.
- Divulgação de Informação (Divulgação de Informação)
- Aplicar políticas de acesso restritas no Azure Key Vault usando RBAC (Controle de Acesso Baseado em Função) do plano de dados.
- Configurar **endpoints** de serviço no Armazenamento do Azure para que o acesso seja restrito a uma Rede Virtual específica (VNet).
- Garantir que todo o tráfego inter-serviços na VNet use criptografia de ponta a ponta e TLS (Segurança da Camada de Transporte) 1.2 ou superior.
- Implementar **Azure Private Link** para acessar serviços PaaS (Plataforma como Serviço) sem expor IPs públicos ou **endpoints** de serviço.
- Remover chaves secretas e informações sensíveis de **templates** ARM, referenciando-os apenas via Key Vault.
- Usar filtros ou mascaramento nos logs do Azure monitorar para anonimizar dados de Informação de Identificação Pessoal (PII).

Information Disclosure

- Habilitar a exclusão suave (Soft Delete) no Azure Key Vault para proteger chaves de criptografia gerenciadas.

Denial of Service

- Habilitar o Azure DDoS (Negação de Serviço Distribuído) Protection Standard nas Redes Virtuais com recursos públicos.
- Utilizar **Load Balancers** e **Application Gateways** com dimensionamento automático (Autoscaling) para gerenciar o tráfego de entrada.
- Implementar políticas de Azure Policy para limitar a alocação excessiva de recursos de alto custo (ex.: IPs públicos) por usuário.
- Monitorar cotas de assinatura através do Azure Service Health e configurar alertas de esgotamento.

Gerado em: 2025-09-28 23:12:14

- Configurar regras de limitação de taxa (limitação de taxa) em *Application Gateways* e *Firewalls* de Aplicação Web (WAF).

Elevation of Privilege

- Implementar o Azure PIM (Privileged Identity Management) para conceder acesso just-in-time (JIT) a funções críticas.
- Garantir que as atribuições de funções RBAC (Controle de Acesso Baseado em Função) sejam feitas no menor escopo possível e revisadas trimestralmente.
- Aplicar Acesso Condicional para proteger contas de administrador com MFA e restrições geográficas.
- Remover a permissão de delegação ampla no AAD que permite a criação ou manipulação de Entidades de Serviço e usuários.
- Usar Políticas de Acesso Condicional para isolar o acesso de Máquinas Virtuais (VMs) a recursos externos via Identidade Gerenciada.
- Auditar e revogar credenciais de contas de serviço com privilégios excessivos para múltiplas assinaturas ou Grupos de Recursos.

Sub-rede Pública da AWS

Análise STRIDE:

Spoofing

- Representação (Spoofing) (Falsificação de Identidade)
- Comprometimento de uma Identidade Gerenciada (*Managed Identity*) associada a um recurso na sub-rede para falsificar a identidade de serviço e acessar outros serviços Azure.

Tampering

- Tentativa de falsificação de IP (*IP Representação (Spoofing)*) nos pacotes de entrada, embora as Redes Virtuais (VNETs) do Azure ofereçam proteções fortes de camada 3 inerentes.
- Uso indevido de certificados *Transport Layer Security* (TLS, Segurança da Camada de Transporte) para se passar por um endpoint público legítimo (requer comprometimento prévio da infraestrutura de gerenciamento de certificados).
- Violação de Integridade (Tampering) (Violação / Adulteração)
- Modificação não autorizada das regras do Grupo de Segurança de Rede (*Network Security Group*, NSG) associado à sub-rede para permitir ou bloquear tráfego de maneira maliciosa.
- Adulteração das Tabelas de Rotas (Route Tables) da sub-rede para redirecionar o tráfego de entrada ou saída para um dispositivo controlado pelo atacante.
- Violação do código ou dados armazenados em discos persistentes (*Managed Disks*) anexados a Máquinas Virtuais públicas.
- Alteração das configurações de *firewall* (ex: *WAF (Firewall de Aplicação Web)*, WAF) para desabilitar filtros de segurança para recursos na sub-rede.

Repudiation

- Modificação dos *logs* de diagnóstico ou auditoria (Azure monitorar) para encobrir rastros de atividade maliciosa dentro da sub-rede.
- Um usuário com alto privilégio realiza alterações críticas nas configurações da sub-rede sem que o *log* de atividade do Azure capture detalhes suficientes para identificar a ação ou o responsável.
- Falha na coleta e retenção dos *logs* de fluxo do NSG (*NSG Flow Logs*), impedindo a comprovação da origem de um ataque de rede ou de vazamento de dados.
- Um recurso dentro da sub-rede executa ações não autorizadas (ex: desprovisionamento de máquinas) sem rastreamento de auditoria da aplicação adequado, dificultando a atribuição.
- Configuração incorreta que permite que administradores apaguem ou modifiquem registros de auditoria importantes que poderiam provar quem executou determinada ação.
- Divulgação de Informação (Divulgação de Informação)
- Exposição de portas administrativas (ex: SSH, RDP) diretamente à internet ou a faixas de IP excessivamente amplas através das regras do NSG.
- Recursos configurados na sub-rede pública que não impõem criptografia *Transport Layer Security* (TLS, Segurança da Camada de Transporte) para proteger o tráfego de dados em trânsito.

Gerado em: 2025-09-28 23:12:14

- Divulgação de metadados da VNet ou informações internas do sistema (ex: versões de software, caminho de arquivo) através de mensagens de erro detalhadas em aplicações web.
- Armazenamento de dados sensíveis em discos não criptografados anexados a recursos na sub-rede.
- Recursos públicos na sub-rede acessando serviços de armazenamento ou bancos de dados internos usando credenciais codificadas de forma insegura.

Information Disclosure

- Um atacante obtém credenciais de acesso ou chaves privadas para recursos expostos (ex: Máquinas Virtuais, Gateways) hospedados na sub-rede pública do Azure.

Denial of Service

- Um ataque de Negação de Serviço Distribuído (*Distributed Negação de Serviço*, DDoS) excede a capacidade de processamento dos serviços públicos, tornando-os indisponíveis para usuários legítimos.
- Exaustão da capacidade de portas ou do espaço de endereçamento IP dentro da sub-rede, impedindo o provisionamento de novos recursos ou a comunicação de serviços existentes.
- Um recurso (ex: *Load Balancer* ou Máquina Virtual) na sub-rede sofre de exaustão de recursos internos (CPU, memória) devido a uma carga maliciosa ou ineficiente.
- Atingir limites de taxa (*limitação de taxa*) impostos pelo Azure sobre recursos específicos (ex: Application Gateway, Firewalls), bloqueando o tráfego legítimo.

Elevation of Privilege

- Um atacante explora uma vulnerabilidade de sistema operacional ou software em um recurso público (ex: servidor web) para obter privilégios de nível de sistema (administrador/root).
- Configuração excessiva de permissões *controle de acesso baseado em função (RBAC)* (RBAC, Controle de Acesso Baseado em Função) no escopo da sub-rede ou VNet, permitindo a um usuário de baixo privilégio gerenciar recursos críticos.
- Um atacante que compromete um servidor de baixo privilégio usa esse acesso para sequestrar tokens ou chaves de acesso que permitem o acesso a outros recursos Azure.
- Um atacante explora falhas no isolamento de rede imposto pelo Azure para acessar sub-redes privadas ou recursos de gerenciamento que não deveriam ser acessíveis.

Mitigações sugeridas:

Spoofing

- Falsificação de Identidade (Representação (Spoofing))
- Implementar a Autenticação Multifator (MFA) obrigatória para todas as contas de usuário e administradores que acessam a infraestrutura do Azure.
- Aplicar o princípio do menor privilégio na atribuição de permissões para Identidades Gerenciadas (*Identidade Gerenciada*).

Tampering

- Restringir o acesso administrativo a Máquinas Virtuais (VMs) usando o acesso just-in-time (JIT) ou o serviço Azure Bastion.
- Garantir que todos os *endpoints* públicos usem versões atuais e seguras do protocolo Transport Layer Security (TLS, *Segurança da Camada de Transporte*).
- Implementar políticas de Acesso Condicional do Azure que avaliem o risco e a conformidade do dispositivo antes de conceder acesso.
- Violação / Adulteração (Violação de Integridade (Tampering))
- Restringir a permissão para modificar regras de Grupos de Segurança de Rede (NSG) e Tabelas de Rotas através de políticas *controle de acesso baseado em função (RBAC)* (RBAC, *Controle de Acesso Baseado em Função*).
- Habilitar a monitoria de integridade de arquivos (*File Integrity Monitoring*) nas Máquinas Virtuais para detectar alterações não autorizadas em binários ou configurações críticas.
- Utilizar políticas do Azure para auditar e impor configurações de segurança obrigatórias, como regras de *firewall* e *WAF (Firewall de Aplicação Web)* (WAF).

Repudiation

Gerado em: 2025-09-28 23:12:14

- Proteger os *logs* de auditoria e diagnóstico, enviando-os para um *storage* imutável (WORM, *Write Once Read Many*) e aplicando Bloqueios de Recursos.
- Garantir a coleta e retenção obrigatória dos *logs* de Atividade do Azure (*Activity Logs*) para rastrear todas as operações de plano de controle.
- Implementar *NSG Flow Logs* para todas as sub-redes críticas, permitindo a análise do tráfego de rede e a atribuição de origem.
- Configurar a segregação de tarefas (separation of duties) via *controle de acesso baseado em função (RBAC)* (RBAC) para garantir que quem gera a auditoria não possa alterá-la.
- Assegurar que todas as ações administrativas sejam realizadas por identidades únicas e não por contas de serviço genéricas ou compartilhadas.
- Utilizar o Azure Policy para impedir a exclusão ou modificação de recursos de *log* de retenção crítica.
- Divulgação de Informação (Divulgação de Informação)
- Configurar regras de Grupo de Segurança de Rede (NSG) para expor portas administrativas (SSH/RDP) apenas a faixas de IP internas ou a serviços de gerenciamento específicos (ex: Azure Bastion).
- Aplicar o protocolo Transport Layer Security (TLS, *Segurança da Camada de Transporte*) 1.2 ou superior em todos os *endpoints* públicos para criptografar dados em trânsito.
- Remover credenciais codificadas de forma insegura, utilizando *Identidade Gerenciada* para autenticação de serviço para serviço dentro do Azure.
- Configurar os servidores web para suprimir informações detalhadas do sistema em mensagens de erro ou cabeçalhos HTTP de resposta.
- Garantir que todos os dados sensíveis em repouso sejam armazenados em discos ou serviços (ex: Azure Storage) que forcem a criptografia.

Information Disclosure

- Armazenar todas as chaves privadas e credenciais de serviço sensíveis exclusivamente no Azure Key Vault, em vez de armazená-las no código.
- Implementar criptografia de disco de ponta a ponta (como Azure Disk Encryption ou Double Encryption) para proteger dados em Discos Gerenciados.

Denial of Service

- Habilitar o Azure DDoS Protection Standard na Rede Virtual (VNet) para proteger contra ataques de Negação de Serviço Distribuído (DDoS, *Distributed Negação de Serviço*) de Camada 3 e 4.
- Implementar o *WAF (Firewall de Aplicação Web)* (WAF) na frente de aplicações web para oferecer proteção de Camada 7, incluindo limitação de taxa (*limitação de taxa*).
- Configurar o dimensionamento automático (*autoscaling*) horizontal para Máquinas Virtuais ou *sets* de escala para lidar com aumentos repentinos de carga.
- Monitorar de forma proativa o uso de recursos (CPU, memória, conexões) via Azure monitorar para detectar exaustão e acionar alertas.
- Dimensionar adequadamente os serviços de Gateway e *Load Balancer* para que suportem picos esperados de tráfego sem atingir limites de taxa (*limitação de taxa*) do Azure.

Elevation of Privilege

- Aplicar o modelo de privilégio mínimo em todas as atribuições *controle de acesso baseado em função (RBAC)* (RBAC, *Controle de Acesso Baseado em Função*) para limitar as ações que um usuário pode realizar.
- Utilizar o Azure *Privileged Identity Management* (PIM) para conceder acesso de alto privilégio somente sob demanda e por tempo limitado.
- Implementar e manter um processo rigoroso de gerenciamento de *patches* e vulnerabilidades em todos os sistemas operacionais hospedados.
- Restringir o movimento lateral (lateral movement) configurando Grupos de Segurança de Rede (NSGs) que isolam o tráfego entre sub-redes.
- Garantir que as Identidades Gerenciadas associadas aos recursos públicos tenham apenas as permissões necessárias para interagir com os serviços de *backend* específicos.

Gerado em: 2025-09-28 23:12:14

Análise STRIDE:

Spoofing

- Comprometimento de uma Identidade Gerenciada (Managed Identity) associada a recursos do Azure que são usados para enviar logs, permitindo que um invasor injete dados maliciosos.
- Falta de correlação clara entre o registro de um evento de log e a identidade exata da aplicação ou *pipeline* que o gerou, permitindo que a origem negue a ação.

Tampering

- Falsificação
- Obtenção e uso indevido de uma Chave de API de Coletor de Dados (Data Collector API Key) para se passar por um recurso legítimo e enviar telemetria falsa para o *workspace* do Azure monitorar.
- Tentativas de *Representação (Spoofing)* contra o agente de monitoramento do Azure em máquinas virtuais para desativar ou redirecionar a coleta de dados de saúde.
- Uso indevido de Contas de Serviço (Service Principal) com permissões excessivas no Controle de Acesso Baseado em Função (RBAC) para mascarar a origem de modificações em regras de alerta.
- Violação/Adulteração
- Modificação ou exclusão das regras de alerta (Alert Rules) configuradas no Azure monitorar para impedir a detecção de atividades suspeitas futuras.
- Injeção de eventos falsos ou alteração de *timestamps* em logs já existentes no Log Analytics para confundir investigadores ou ocultar ações passadas.
- Alteração das configurações de *endpoints* de exportação de dados, redirecionando logs críticos para um armazenamento não seguro ou sob controle do atacante.
- Manipulação das métricas de desempenho coletadas para ocultar o impacto real de um ataque de sobrecarga em um serviço monitorado.
- Divulgação de Informação
- Acesso não autorizado a *queries* KQL (Linguagem de Consulta Kusto) salvas que contêm detalhes confidenciais sobre a infraestrutura e a topologia da aplicação.

Repudiation

- Adulteração das configurações de *data retention* (retenção de dados) do Log Analytics, resultando na exclusão prematura de evidências críticas de segurança.
- Não configuração de trilhas de auditoria (por exemplo, via Azure Activity Log) que rastreiem quem acessou, modificou ou consultou dados sensíveis no Log Analytics.
- Ausência de logs de auditoria sobre a exclusão ou reconfiguração de *workspaces* inteiros do Azure monitorar.
- Configuração incorreta do Controle de Acesso Baseado em Função (RBAC), permitindo que usuários não autorizados visualizem logs de ambientes altamente regulamentados (produção, PCI, etc.).
- Logs de diagnóstico detalhados revelando vulnerabilidades ou informações internas que podem ser usadas para planejar ataques.

Information Disclosure

- Exposição de dados sensíveis (senhas, chaves de API, Informações Pessoais Identificáveis - PII) que foram inadvertidamente registrados nos logs de aplicações (via Application Insights ou Log Analytics).
- Vazamento de dados durante a exportação ou arquivamento de logs para o Armazenamento do Azure se as configurações de segurança, como criptografia e Segurança da Camada de Transporte (TLS), não forem aplicadas corretamente.

Denial of Service

- Negação de Responsabilidade
- Um usuário com acesso administrativo nega ter desativado um grupo de ação (Action Group) que deveria ter notificado a equipe de segurança sobre um incidente.
- Sobrecarga intencional do *endpoint* de ingestão de logs do Log Analytics, fazendo com que o Azure Monito descarte dados críticos de saúde e segurança devido a limites de taxa.
- Execução de consultas KQL excessivamente complexas e demoradas, exaurindo recursos computacionais do *workspace* e impedindo que consultas legítimas de monitoramento sejam concluídas.
- Criação de alertas falsos e maciços (alert storm) que inundam os canais de notificação e mascaram alertas reais de incidentes de segurança.

Gerado em: 2025-09-28 23:12:14

- Exclusão ou desabilitação de todos os agentes de monitoramento em recursos críticos, impedindo a coleta de métricas necessárias para manter a disponibilidade.
- Atingir o limite máximo de armazenamento ou o limite diário de ingestão de dados, levando à interrupção da coleta de logs e métricas.

Elevation of Privilege

- Exploração de permissões de leitura mal configuradas no RBAC para obter acesso a informações de **token** ou chaves de conexão que permitam ações de escrita/modificação de dados.
- Um usuário com permissão de manipulação de logs consegue alterar dados de auditoria que, subsequentemente, levam a uma elevação de privilégio em outro sistema que confia nessa informação.
- Exploração de uma chave de API do Coletor de Dados para injetar **payloads** que elevam o controle sobre outros sistemas que consomem os logs.
- Obtenção de permissão para alterar as configurações de diagnóstico de recursos, permitindo que o atacante direcione os dados críticos para um **workspace** sob seu controle.

Mitigações sugeridas:

Spoofing

- Restringir o escopo e as permissões de Identidades Gerenciadas ao mínimo necessário para a ingestão de logs.
- Implementar a Autenticação Multifator (MFA) para todas as identidades que acessam recursos críticos do Azure monitorar.
- Evitar o uso de Chaves de API de Coletor de Dados (Data Collector API Keys), preferindo Identidades Gerenciadas para autenticação.

Tampering

- Falsificação
- Forçar a comunicação por meio de canais seguros usando a Segurança da Camada de Transporte (TLS 1.2+) para todos os agentes de monitoramento.
- Violação/Adulteração
- Proteger as regras de alerta e os grupos de ação com Controle de Acesso Baseado em Função (RBAC) granular, limitando o acesso de modificação.
- Aplicar bloqueios de recursos (bloqueios de recursos) no **workspace** do Log Analytics para prevenir a exclusão ou alteração de configurações de retenção.
- Divulgação de Informação
- Restringir o acesso a **queries** KQL salvas que contenham informações confidenciais sobre a topologia da infraestrutura.

Repudiation

- Habilitar a proteção de ingestão de logs para rejeitar logs com **timestamps** fora do intervalo aceitável ou de forma retroativa.
- Usar trilhas de auditoria (via Azure Activity Log) para monitorar e alertar sobre mudanças nas configurações de exportação de dados.
- Implementar o Bloqueio de Imutabilidade (Immutability Lock) no Armazenamento do Azure para logs arquivados.
- Garantir que o Log de Atividades do Azure (Azure Activity Log) esteja habilitado para registrar todas as operações de plano de controle e gestão.
- Configurar a exportação de logs de auditoria para um **workspace** separado, seguro e com retenção de longo prazo.
- Usar o Azure Policy para impor que todos os **workspaces** capturem logs de auditoria de consulta e acesso a dados.
- Garantir que os logs de aplicação incluam identificadores únicos de sessão ou transação para correlação exata da origem.
- Monitorar e alertar sobre tentativas de desativação de grupos de ação (Action Groups) ou de trilhas de auditoria críticas.
- Utilizar o recurso de Limpeza de Log (Log Scrubbing) ou a função de **purge** (limpeza) do Azure monitorar para remover dados sensíveis ingeridos.
- Aplicar o Controle de Acesso Baseado em Função (RBAC) no nível de tabela (Table-level RBAC) para segmentar o acesso dentro do Log Analytics.

Gerado em: 2025-09-28 23:12:14

- Usar Criptografia em Trânsito (Segurança da Camada de Transporte - TLS) e Criptografia em Repouso para todos os dados de log.
- Revisar e testar permissões de leitura do Controle de Acesso Baseado em Função (RBAC) para limitar estritamente a visualização de logs por ambiente.

Denial of Service

- Negação de Responsabilidade
- Configurar o Limite de Ingestão Diária (Daily Cap) no Log Analytics para gerenciar o volume de dados e priorizar logs críticos.
- Implementar o *cluster* dedicado do Log Analytics para garantir recursos computacionais reservados para consultas críticas.
- Configurar regras de Silenciamento de Alerta (Alert Suppression) para evitar "tempestades de alerta" (alert storms) em eventos massivos.
- Monitorar o volume de ingestão em tempo real e alertar quando a taxa se aproximar dos limites de serviço.
- Restringir a execução de consultas KQL *ad-hoc* complexas a usuários autorizados e exigir otimização.

Elevation of Privilege

- Usar o Controle de Acesso Baseado em Função (RBAC) com o princípio do menor privilégio em Contas de Serviço (Service Principal).
- Aplicar o princípio de separação de deveres (Separation of Duties) no Controle de Acesso Baseado em Função (RBAC).
- Monitorar e alertar sobre qualquer alteração nas configurações de Diagnóstico de recursos que possam redirecionar dados.
- Garantir que nenhum segredo ou *token* de conexão esteja acessível via logs ou via *queries* KQL salvas.
- Limitar as permissões de Contas de Serviço para a manipulação de logs, separando-as das permissões de gestão de configuração do *workspace*.
- Usar o Acesso Condicional do Azure para exigir que ações de alto risco no Azure monitorar sejam realizadas a partir de dispositivos compatíveis.

Serviço de Computação AWS (EC2/Fargate)

Análise STRIDE:

Spoofing

- Comprometimento de uma Identidade Gerenciada (Managed Identity) associada à Máquina Virtual (VM) ou ao Serviço de Contêineres, permitindo que a instância se passe por outro recurso ou serviço dentro do Azure.

Tampering

- Falsificação
- Criação de contas de serviço maliciosas dentro de clusters de containers (como o Serviço de Kubernetes do Azure - AKS) para mascarar atividades não autorizadas.
- Violação
- Modificação não autorizada de imagens de disco (imagens de Máquina Virtual ou imagens de container) antes de serem implantadas ou durante a execução, introduzindo código malicioso.
- Alteração das regras de Grupo de Segurança de Rede (NSG) ou do Firewall do Azure que protegem o recurso de computação, desviando o tráfego legítimo ou expondo portas sensíveis.

Repudiation

- Manipulação de logs de auditoria e monitoramento dentro da VM ou do ambiente de contêiner para ocultar atividades maliciosas.
- Falha na implementação de registro de acesso (logging) detalhado para operações administrativas críticas dentro da Máquina Virtual, impedindo a rastreabilidade das ações de administradores ou usuários privilegiados.
- Ausência de logs de atividade (Activity Logs) robustos para registrar quem iniciou ações de ciclo de vida do recurso, como reinicialização, exclusão ou redimensionamento da VM ou do Contêiner.

Gerado em: 2025-09-28 23:12:14

- Uso de credenciais de acesso compartilhadas ou genéricas para acesso aos sistemas operacionais internos ou ao ambiente de execução de contêineres, impossibilitando a identificação do usuário responsável por uma ação destrutiva.

Information Disclosure

- Uso indevido ou roubo de chaves SSH ou credenciais armazenadas para acesso administrativo direto ao sistema operacional da VM, permitindo a atuação como administrador do sistema.
- Falsificação de metadados da instância (Azure Instance Metadata Service) para obter tokens de acesso ou informações confidenciais sobre o ambiente hospedeiro.
- Violação da integridade de dados em trânsito devido à configuração incorreta ou ausência de Transport Layer Security (TLS), um protocolo criptográfico que garante comunicações seguras, ou outros protocolos de criptografia de rede.
- Exposição acidental de segredos (chaves de API, senhas, cadeias de conexão) armazenados em variáveis de ambiente de contêiner ou em arquivos de configuração da VM não criptografados.
- Falha na criptografia de dados em repouso nos discos de armazenamento (Azure Managed Disks), permitindo o acesso direto aos dados sensíveis caso o disco seja anexado a outro recurso.
- Divulgação de informações através de portas de diagnóstico abertas ou serviços de monitoramento internos não autenticados, expondo métricas de desempenho ou dados de memória.
- Configuração incorreta de logs ou saída (standard output) do container, que inadvertidamente registram informações de PII (Informação Pessoal Identificável) ou chaves de acesso.

Denial of Service

- Exaustão dos recursos de CPU, memória ou rede da Máquina Virtual ou do Contêiner através de ataques de Distributed Negação de Serviço (DDoS), um ataque distribuído de negação de serviço, ou por processos internos mal configurados.
- Consumo excessivo de limites de cota de serviço (Service Limits) ou de largura de banda de rede associada à VM, impedindo a comunicação com serviços externos.
- Saturação do disco gerenciado da VM através de escrita excessiva de dados ou logs, resultando em falha da aplicação ou indisponibilidade do sistema operacional.
- Exploração de vulnerabilidades no kernel do sistema operacional da VM ou no runtime do contêiner para causar travamentos (crashes) recorrentes do serviço de computação.

Elevation of Privilege

- Exploração de vulnerabilidades de configuração ou software dentro do sistema operacional da VM (exploits de escalonamento local) para obter acesso de nível de `root` ou `administrador`.
- Acesso não autorizado ao plano de controle do Azure (Azure Control Plane) através de uma identidade de serviço comprometida (como um Principal de Serviço), permitindo alterar o nível de acesso do recurso.
- Configuração inadequada do controle de acesso baseado em função (RBAC) (RBAC), um sistema de controle de acesso baseado em função, permitindo que um usuário ou serviço com permissões limitadas execute ações de alto privilégio no recurso de computação.
- Fuga do contêiner (container escape) para obter acesso ao sistema operacional hospedeiro (host OS) do Azure, elevando o privilégio para além do isolamento do container.

Mitigações sugeridas:

Spoofing

- Implementar autenticação multifator (MFA) para todo acesso administrativo ao sistema operacional.
- Aplicar o princípio do menor privilégio nas identidades gerenciadas (Identidade Gerenciada) atribuídas ao recurso.
- Exigir a validação da identidade da carga de trabalho em clusters do Serviço de Kubernetes do Azure (AKS) usando ID de Carga de Trabalho do Azure AD.

Tampering

- Falsificação
- Restringir o acesso ao Serviço de Metadados da Instância (IMDS) através de firewalls locais e políticas de rede.
- Forçar a rotação regular de chaves e certificados de serviço usando o Azure Key Vault.
- Violação

Gerado em: 2025-09-28 23:12:14

- Utilizar políticas do Azure para impor a imutabilidade das configurações de Grupo de Segurança de Rede (NSG) e Firewall do Azure.
- Assinar e validar imagens de Máquina Virtual e contêineres usando o Registro de Contêiner do Azure (ACR).
- Impor o uso de Transport Layer Security (TLS), um protocolo criptográfico que garante comunicações seguras, versão 1.2 ou superior para todos os dados em trânsito.
- Implementar rastreamento de mudanças para alertar sobre modificações não autorizadas em arquivos críticos do sistema operacional.
- Utilizar o Microsoft Defender for Cloud para monitorar a integridade de arquivos do sistema operacional (File Integrity Monitoring).

Repudiation

- Garantir a coleta de logs de segurança em um armazenamento imutável, como o Azure Storage com retenção bloqueada.
- Forçar o uso de contas individuais e a desativação de credenciais de acesso compartilhadas ou genéricas.
- Implementar logs de atividade (Activity Logs) detalhados e abrangentes para registrar todas as ações de ciclo de vida do recurso.
- Configurar o acesso just-in-time (acesso no momento) para acesso administrativo, garantindo a rastreabilidade individual.
- Habilitar logs de diagnóstico detalhados para todas as operações administrativas e comandos executados no sistema operacional.
- Garantir a retenção de logs de auditoria por um período compatível com as exigências regulatórias.

Information Disclosure

- Usar o Azure Key Vault para armazenar e gerenciar chaves SSH e credenciais sensíveis.
- Criptografar dados em repouso nos discos gerenciados (Managed Disks) usando a Criptografia de Disco do Azure (ADE).
- Migrar todos os segredos (chaves de API, senhas) de variáveis de ambiente para o Azure Key Vault.
- Aplicar restrições de rede e autenticação fortes para todas as portas de diagnóstico e serviços de monitoramento internos.
- Configurar a supressão de informações sensíveis ou PII (Informação Pessoal Identificável) nos logs e na saída padrão do contêiner.
- Utilizar o Verificador de Credenciais (Credential Scanner) para evitar o armazenamento acidental de segredos no código-fonte.
- Desativar portas de gerenciamento abertas (RDP, SSH) e usar Azure Bastion para acesso seguro.

Denial of Service

- Habilitar o Azure Distributed Negação de Serviço (DDoS) Protection Standard, um ataque distribuído de negação de serviço, na rede virtual associada.
- Configurar o dimensionamento automático (auto-scaling) para grupos de Máquinas Virtuais e pods de contêiner para absorver picos de tráfego.
- Implementar limites de recursos (resource quotas) e limites de taxa em serviços de API para evitar exaustão.
- Monitorar e implementar alertas proativos para saturação de disco ou alto consumo de recursos de CPU e memória.
- Aplicar gerenciamento rigoroso de cotas de serviço (Service Limits) para evitar o consumo excessivo de largura de banda.
- Utilizar uma política de atualização de imagem para garantir que o kernel do sistema operacional e o runtime do contêiner estejam sempre corrigidos.

Elevation of Privilege

- Aplicar o princípio do menor privilégio consistentemente através do controle de acesso baseado em função (RBAC) (RBAC), um sistema de controle de acesso baseado em função.
- Implementar o Gerenciamento de Identidade Privilegiada (PIM) do Azure AD para acesso just-in-time a funções de alto privilégio.
- Realizar o endurecimento (hardening) do sistema operacional da VM e do ambiente de execução do contêiner conforme benchmarks de segurança.
- Usar o Microsoft Defender for Cloud para detectar vulnerabilidades e anomalias de escalonamento local.

Gerado em: 2025-09-28 23:12:14

- Configurar o Azure Policy para restringir permissões que permitam o acesso direto ao plano de controle (Control Plane) do Azure.
- Restringir as capacidades perigosas do contêiner (como acesso ao ``docker.sock``) e impor políticas de segurança de pod no AKS.

Logo da AWS Cloud

Análise STRIDE:

Spoofing

- Falsificação de Identidade (Representação (Spoofing))
- Criação de portais de gestão Azure falsos (phishing) utilizando o ícone ou esquema de cores para enganar usuários e roubar credenciais de acesso.
- Uso indevido de identidades gerenciadas (Identidade Gerenciada) associadas a funções de exibição de ativos, permitindo que um serviço se passe por outro na recuperação da imagem.

Tampering

- Hospedagem de recursos externos (ex: a imagem do logotipo) em subdomínios de contas de Armazenamento de Blobs (Blob Storage) Azure para mascarar a origem real do conteúdo.
- Substituição de ícones de recursos no portal Azure por ativos de nuvens concorrentes (como a logomarca da AWS), confundindo auditores e usuários sobre a origem do recurso.
- Violação (Violação de Integridade (Tampering))
- Modificação não autorizada do ativo gráfico armazenado no serviço de Armazenamento de Blobs (Blob Storage) Azure, resultando na exibição de uma imagem maliciosa ou inadequada.
- Alteração das políticas de CORS (Compartilhamento de Recursos de Origem Cruzada) no Armazenamento de Blobs, permitindo que terceiros modifiquem ou substituam o ativo visual através de requisições maliciosas.
- Comprometimento das chaves SAS (Assinatura de Acesso Compartilhado) associadas ao contêiner de armazenamento, permitindo a um ator malicioso sobrescrever o arquivo do logotipo.

Repudiation

- Falta de rastreabilidade e log (auditoria) sobre qual identidade (usuário ou principal de serviço) alterou as configurações de acesso público do contêiner de armazenamento que hospeda o ativo visual.
- Ausência de trilhas de auditoria detalhadas no Azure monitorar sobre quem realizou o `*upload*` ou a exclusão do ativo visual, permitindo que o responsável negue a ação.
- Configuração incorreta do registro de atividades (Activity Log) para eventos de Armazenamento Azure, impossibilitando a prova de quem distribuiu o ativo adulterado.
- Incapacidade de correlacionar logs de CDN (Rede de Distribuição de Conteúdo) com os logs de acesso ao Armazenamento de Blobs para determinar a origem da violação.
- Divulgação de Informação (Divulgação de Informação)
- Exposição de nomes de Contas de Armazenamento (Storage Accounts) ou URLs de CDN (Rede de Distribuição de Conteúdo) que deveriam ser privadas, revelando a topologia interna dos recursos Azure.
- O ativo visual (o logotipo) contendo metadados embarcados que expõem detalhes internos, como nomes de máquinas virtuais ou diretórios de desenvolvimento.
- Configuração acidental da Conta de Armazenamento para acesso anônimo público, permitindo a enumeração de outros arquivos e `*blobs*` confidenciais no mesmo contêiner.
- Vazamento de informações de versão ou `*tags*` de ambiente (ex: Produção, Desenvolvimento) através das propriedades do ativo no Azure Resource Manager (Gerenciador de Recursos Azure).

Denial of Service

- Adulteração dos metadados da imagem para injetar código (em formatos como SVG) ou referências perigosas que são executadas pelo navegador do usuário ao renderizar a interface de gestão.
- Saturação dos limites de requisição da CDN (Rede de Distribuição de Conteúdo) Azure ou do Armazenamento de Blobs através de ataques de grande volume (DDoS, por exemplo, Negação de Serviço Distribuída), impedindo a correta exibição do ativo.

Gerado em: 2025-09-28 23:12:14

- Substituição do ativo por um arquivo de imagem excessivamente grande ou malformato que sobrecarrega os navegadores dos usuários ao tentar renderizar a interface de gestão.
- Exclusão ou desabilitação da Conta de Armazenamento que hospeda a imagem, tornando a interface de gestão inoperante ou visualmente quebrada.
- Configuração de regras de WAF (Firewall de Aplicação Web) no Azure Application Gateway que bloqueiam erroneamente o tráfego legítimo para o ativo visual.

Elevation of Privilege

- Uso de permissões excessivas concedidas via RBAC (Controle de Acesso Baseado em Função) para a identidade que gerencia os ativos de branding, permitindo que um administrador de ativos visualize ou modifique dados confidenciais não relacionados na Conta de Armazenamento.
- Exploração de vulnerabilidades em serviços de terceiros integrados ao Azure Marketplace que renderizam ou processam o logotipo, para obter acesso de nível superior ao plano de controle do Azure.
- Concessão da função de "Contribuidor de Dados de Blob de Armazenamento" a um usuário que só precisaria da função de "Leitor de Dados de Blob de Armazenamento", permitindo modificações indevidas.
- Um ator comprometido usa o processo de *upload* de um novo ativo visual para acionar uma função *serverless* (sem servidor) do Azure Functions com permissões elevadas de forma não intencional.

Mitigações sugeridas:

Spoofing

- Falsificação de Identidade (Representação (Spoofing))
- Implementar Autenticação Multifator (MFA) obrigatória para todos os usuários que acessam o portal Azure e recursos de gestão.
- Utilizar Azure Defender para Identidade para detectar anomalias e tentativas de *phishing* de credenciais de acesso.
- Revisar e minimizar as permissões concedidas às Identidades Gerenciadas, aderindo ao princípio do menor privilégio.

Tampering

- Aplicar políticas de Acesso Condicional (Conditional Access) para restringir o acesso à gestão Azure a dispositivos e redes confiáveis.
- Usar o Azure Front Door ou CDN (Rede de Distribuição de Conteúdo) com regras de WAF (Firewall de Aplicação Web) para validar a origem das requisições.
- Violação (Violação de Integridade (Tampering))
- Implantar políticas de Imutabilidade (Immutability Policy) para os *blobs* que contêm os ativos de *branding* após a aprovação do conteúdo.
- Limitar as permissões de escrita (gravação) no Armazenamento de Blobs apenas a *Service Principal* (entidades de serviço) automatizados e auditados.
- Utilizar Chaves SAS (Assinatura de Acesso Compartilhado) de serviço com tempo de vida muito curto e permissões estritamente necessárias (ex: apenas escrita, sem exclusão).
- Configurar regras de CORS (Compartilhamento de Recursos de Origem Cruzada) no Armazenamento de Blobs para aceitar requisições de modificação somente de origens específicas e confiáveis.
- Implementar escaneamento de conteúdo e metadados no momento do *upload* para bloquear arquivos com código injetado (ex: SVG ou metadados executáveis).

Repudiation

- Garantir que o Log de Atividades (Activity Log) do Azure esteja habilitado para registrar todas as alterações de configurações de acesso no Armazenamento.
- Encaminhar logs de diagnóstico do Armazenamento de Blobs para um *workspace* de Análise de Log (Log Analytics) com retenção estendida e imutável.
- Utilizar políticas do Azure Policy para exigir o registro detalhado de eventos de *upload*, exclusão e modificação de *blobs*.
- Configurar o rastreamento de logs no Azure CDN para incluir metadados que permitam a correlação precisa com os logs de acesso à Conta de Armazenamento.
- Usar trilhas de auditoria do Azure monitorar para rastrear qual Identidade Gerenciada ou principal de serviço realizou ações no plano de dados do armazenamento.
- Divulgação de Informação (Divulgação de Informação)

Gerado em: 2025-09-28 23:12:14

- Usar *endpoints* privados do Azure (Private Endpoints) para acessar o Armazenamento de Blobs, ocultando as URLs internas de acesso.
- Implementar processos de higienização (*scrubbing*) de metadados em todos os ativos visuais antes do *upload* para remover dados internos (ex: tags de desenvolvimento).
- Garantir que a Conta de Armazenamento não permita acesso anônimo público, impedindo a enumeração de outros *blobs* no contêiner.
- Aplicar o Azure Policy para negar a criação de Contas de Armazenamento com o acesso de listagem de contêineres habilitado para usuários anônimos.
- Restringir o acesso às Tags (etiquetas) de Recurso Azure para usuários de gestão, evitando a exposição de detalhes de ambiente (Produção/Desenvolvimento).

Denial of Service

- Habilitar o Azure DDoS Protection Standard na VNet (Rede Virtual) associada aos serviços de *front-end* (CDN ou Front Door).
- Configurar o Azure CDN para cacheamento de longo prazo dos ativos visuais, reduzindo a carga de requisições na origem (Armazenamento).
- Implementar um WAF (Firewall de Aplicação Web) no Azure Front Door para aplicar limitação de taxa (limitação de taxa) e filtragem de IPs maliciosos.
- Definir limites de tamanho de arquivo no portal Azure ou via política para rejeitar *uploads* de ativos gráficos excessivamente grandes ou malformados.
- Usar replicação de Conta de Armazenamento Georredundante (GRS) para alta disponibilidade e rápida restauração em caso de exclusão da origem.

Elevation of Privilege

- Aplicar o princípio do menor privilégio usando funções RBAC (Controle de Acesso Baseado em Função) personalizadas com ações restritas ao *scope* (escopo) do contêiner específico.
- Implementar Acesso just-in-time (JIT) e Azure PIM (Gerenciamento de Identidade Privilegiada) para acesso temporário e auditável a funções com privilégios de gestão.
- Auditar e remover atribuições de funções amplas como "Contribuidor de Dados de Blob de Armazenamento", substituindo-as por "Leitor" quando a escrita não for necessária.
- Garantir que qualquer função *serverless* (sem servidor) (ex: Azure Functions) acionada por *upload* opere com uma Identidade Gerenciada dedicada de baixo privilégio.
- Isolar recursos de ativos visuais em Contas de Armazenamento separadas de dados confidenciais para limitar o impacto de um comprometimento.

VPC Privada da AWS

Análise STRIDE:

Spoofing

- Falsificação de Identidade (Representação (Spoofing))
- Utilização de uma Identidade Gerenciada (Managed Identity) comprometida para falsificar um serviço legítimo do Azure dentro da Rede Virtual (VNet).

Tampering

- Tentativas de personificação de um recurso de Ponto Privado (Private Endpoint) para desviar o tráfego que deveria ser direcionado a um serviço PaaS específico.
- Comprometimento de uma credencial de acesso de usuário do Azure Active Directory (Azure AD) para acessar o plano de controle da VNet e alterar configurações de sub-redes.
- Falsificação de endereços IP de origem dentro de uma sub-rede para burlar regras de Grupos de Segurança de Rede (NSG - Network Security Groups) se o recurso não estiver configurado para proteção contra falsificação de IP.
- Violação/Adulteração (Violação de Integridade (Tampering))
- Modificação não autorizada nas regras de um Grupo de Segurança de Rede (NSG) associado à sub-rede, permitindo a entrada ou saída de tráfego malicioso.

Gerado em: 2025-09-28 23:12:14

- Adulteração das Tabelas de Rotas Definidas pelo Usuário (UDRs - User Defined Routes) forçando o tráfego privado a passar por um dispositivo de terceiros não confiável.
- Alteração das configurações de ímã de uma VNet pareada (VNet Peering) para injetar tráfego em uma rede vizinha de maior sensibilidade.
- Modificação ou remoção dos Bloqueios de Recursos do Azure (bloqueios de recursos) aplicados à VNet ou às sub-redes críticas.

Repudiation

- Falta de rastreabilidade completa das ações de um administrador que removeu ou modificou um Ponto de Serviço (Service Endpoint) antes que os registros de log fossem retidos de forma imutável.
- Execução de comandos de infraestrutura como código (IaC) para provisionar ou desprovisionar recursos na VNet sem a correta aplicação de assinaturas digitais ou registros de auditoria à prova de adulteração.
- Ausência de logs de fluxo do Azure Network Watcher que possam confirmar qual usuário ou serviço desativou a funcionalidade de registro durante um ataque.

Information Disclosure

- Exposição de endereços IP privados internos e mapeamento de sub-redes devido a configurações incorretas de DNS ou vazamento de metadados em logs públicos.
- Configuração incorreta de regras de NSG ou de firewall que permitem a resposta de sondagem (probe) de portas, revelando a topologia interna da rede privada.
- Captura de tráfego não criptografado (por exemplo, HTTP simples) que trafega entre máquinas virtuais dentro da VNet, expondo dados sensíveis.
- Vazamento de chaves secretas ou credenciais de serviços armazenadas em máquinas virtuais dentro da VNet, que são acessíveis através de acesso lateral (lateral movement).

Denial of Service

- Saturação da largura de banda da VNet através de ataques volumétricos externos, mitigáveis parcialmente pelo serviço de Proteção DDoS do Azure.
- Esgotamento dos recursos de uma Máquina Virtual de Rede (NVA - Network Virtual Appliance) crítica (como o Azure Firewall) implantada na sub-rede, impedindo a inspeção de tráfego legítimo.
- Saturação dos recursos de Ponto de Serviço ou Ponto Privado, impedindo que as máquinas virtuais acessem serviços PaaS essenciais (como Azure SQL ou Key Vault).
- Consumo excessivo de endereços IP disponíveis dentro da sub-rede por meio do provisionamento de recursos de forma descontrolada, resultando em esgotamento de IP.

Elevation of Privilege

- Exploração de uma configuração de controle de acesso baseado em função (RBAC) (RBAC - Controle de Acesso Baseado em Função) mal definida, permitindo que um usuário com privilégios limitados altere as definições de VNet.
- Utilização de um serviço comprometido com privilégios de "Colaborador de Rede" para ganhar a capacidade de injetar um novo Ponto de Serviço ou Ponto Privado que direcione o tráfego para um recurso malicioso.
- Obtenção de acesso just-in-time (JIT) a um recurso dentro da sub-rede através da burla das políticas de acesso condicional do Azure AD.
- Configuração de NSGs ou de um Azure Firewall que permita o acesso de gestão a partir de uma rede não confiável, facilitando o acesso ao plano de controle da VNet.

Mitigações sugeridas:

Spoofing

- Falsificação de Identidade (Representação (Spoofing))
- Implementar o Azure AD Proteção de Identidade para detectar credenciais comprometidas e logins anômalos.
- Exigir Autenticação Multifator (MFA) para todos os usuários e entidades de serviço que acessam o plano de controle.

Tampering

- Habilitar a proteção contra falsificação de IP (IP Representação (Spoofing) protection) nas interfaces de rede das Máquinas Virtuais (VMs).
- Utilizar Pontos de Serviço ou Ligações Privadas para garantir que a conexão ao serviço PaaS seja validada pela plataforma Azure.

Gerado em: 2025-09-28 23:12:14

- Violação/Adulteração (Violação de Integridade (Tampering))
- Aplicar Bloqueios de Recursos (bloqueios de recursos) de "Somente Leitura" em Grupos de Segurança de Rede (NSG) e Tabelas de Rotas Definidas pelo Usuário (UDR).
- Implementar Azure Policy para auditar e impor a integridade das configurações de NSG e de emparelhamento de VNets (VNet Peering).
- Gerenciar todas as alterações de infraestrutura de rede exclusivamente através de pipelines de Infraestrutura como Código (IaC) auditáveis.

Repudiation

- Monitorar o log de atividades do Azure para alertas imediatos sobre remoção de Bloqueios de Recursos.
- Configurar todos os logs de atividade e de diagnóstico do Azure para retenção de longo prazo com imutabilidade.
- Exigir a aplicação de assinaturas digitais ou chaves de aprovação em todos os comandos de IaC críticos que modificam a VNet.
- Habilitar logs de fluxo do Azure Network Watcher em todas as sub-redes e impor sua ativação via Azure Policy.
- Centralizar logs de auditoria no Azure monitorar ou em um sistema SIEM com rastreabilidade completa de identidade e tempo.
- Garantir que a identidade que executa ações (usuário ou identidade gerenciada) seja registrada de forma imutável nos logs do Azure Activity.

Information Disclosure

- Forçar o uso de criptografia de ponta a ponta (como TLS - Segurança da Camada de Transporte ou IPsec) para todo o tráfego interno na VNet.
- Utilizar o Azure Key Vault (Cofre de Chaves do Azure) para armazenar segredos, impedindo sua exposição em máquinas virtuais.
- Configurar regras de NSG e Azure Firewall para "negar tudo" por padrão, bloqueando sondagens de portas.
- Garantir que a resolução de nomes internos utilize exclusivamente servidores DNS privados, evitando vazamento de metadados.
- Implementar regras no Azure Firewall para inspecionar e bloquear tráfego de saída não autorizado.

Denial of Service

- Ativar o Azure DDoS Proteção Padrão (Standard Protection) para proteger recursos públicos na VNet.
- Dimensionar adequadamente ou habilitar o escalonamento automático (autoscale) das Máquinas Virtuais de Rede (NVA) críticas, como firewalls.
- Aplicar limitação de taxa (limitação de taxa) no Azure Application Gateway ou Azure Front Door para proteger serviços PaaS expostos.
- Planejar o espaço de endereçamento IP das sub-redes com folga para evitar o esgotamento de IP.
- Utilizar o Azure Firewall para inspeção de tráfego e mitigação de ataques de camada 7 para cargas de trabalho aplicáveis.

Elevation of Privilege

- Aplicar o princípio de privilégio mínimo usando RBAC (Controle de Acesso Baseado em Função) para Identidades Gerenciadas.
- Restringir o acesso de escrita (write access) a componentes críticos de rede usando funções RBAC de alto nível.
- Revisar e refinar rigorosamente as atribuições de função RBAC para aderir ao princípio do menor privilégio.
- Implementar o Azure AD PIM (Gerenciamento de Identidade Privilegiada) para acesso just-in-time (JIT) e por tempo limitado ao plano de controle.
- Usar políticas de Acesso Condicional do Azure AD para restringir o acesso administrativo apenas a dispositivos compatíveis e localizações confiáveis.
- Restringir as permissões RBAC que permitem a injeção ou modificação de Pontos de Serviço ou Pontos Privados.
- Isolar o acesso de gestão em uma sub-rede dedicada, protegida por um NSG restritivo e por políticas de Firewall.

Usuários da AWS

Análise STRIDE:

Spoofing

Gerado em: 2025-09-28 23:12:14

- Ataques de **pass-the-hash** ou **pass-the-ticket** que roubam credenciais e permitem que um ator se passe por um usuário legítimo no ambiente Azure.
- Comprometimento de chaves de federação (Protocolo de Autenticação SAML - **Security Assertion Markup Language**) permitindo que um invasor se passe por um provedor de identidade confiável para o Azure Entra ID.
- Uso de **phishing** ou engenharia social para obter credenciais de usuários e realizar o sequestro de sessão (**session hijacking**) em nome de um administrador de alto privilégio.
- Exploração de vulnerabilidades na implementação da autenticação multifator (MFA), permitindo a falsificação de identidade por meio de ataques de exaustão ou fadiga de MFA.
- Violação de Dados/Integridade
- Um usuário com acesso privilegiado modifica as configurações de acesso condicional (**Conditional Access**) para enfraquecer as políticas de segurança e permitir acesso irrestrito a usuários maliciosos.
- Alteração não autorizada de atributos críticos de identidade (ex: redefinição de senha ou mudança de e-mail de recuperação) dentro do Azure Entra ID.
- Modificação de funções de controle de acesso baseado em função (RBAC - **controle de acesso baseado em função (RBAC)**) por um ator não autorizado para conceder a si mesmo ou a terceiros permissões elevadas.
- Violação e alteração de **scripts** de implantação automatizada (**Infrastructure as Code**) por um usuário interno comprometido, introduzindo **backdoors** ou vulnerabilidades de configuração.

Repudiation

- Falha na coleta de logs de auditoria suficientes (em Log Analytics ou Microsoft Sentinel) para rastrear todas as ações críticas executadas por usuários de alto privilégio (ex: Administradores Globais).
- Exclusão ou modificação dos logs de atividade do Azure por um ator comprometido que detém privilégios de limpeza de logs, impedindo a rastreabilidade da atividade maliciosa.
- Ausência de mecanismos de assinatura ou registro imutável que provem que um administrador específico foi responsável por uma alteração crítica na configuração da subscrição.

Information Disclosure

- Acesso não autorizado a dados sensíveis de clientes armazenados em serviços Azure devido à configuração incorreta de permissões RBAC.
- Divulgação acidental de segredos (**segredos**) ou chaves de acesso (**access keys**) em repositórios de código ou em logs de diagnóstico acessíveis por usuários não autorizados.
- Exposição de dados sensíveis da identidade (ex: informações de contato, histórico de grupos) através de consultas de API mal configuradas (ex: Microsoft Graph API).
- Vazamento de informações de autenticação (tokens ou hashes de senha) capturados devido a conexões desprotegidas que não utilizam o protocolo de segurança da camada de transporte (TLS - **Transport Layer Security**).

Denial of Service

- Ataques de negação de serviço distribuído (DDoS - **Distributed Negação de Serviço**) direcionados aos **endpoints** de autenticação do Azure Entra ID ou aos **gateways** de aplicação.
- Tentativas automatizadas de **login** com credenciais inválidas que resultam no bloqueio massivo e não intencional de contas de usuários legítimos, impedindo seu acesso.
- Consumo excessivo e intencional de recursos de computação (ex: **Function Apps** ou **Web Apps**) por um usuário interno, resultando em indisponibilidade para outros serviços essenciais.

Elevation of Privilege

- Exploração de falhas em permissões de atribuição de função que permitem a um usuário criar ou modificar suas próprias permissões ou atribuir funções mais elevadas a si mesmo.
- Elevação de privilégio obtida através do comprometimento de uma identidade de serviço (**Service Principal** ou Identidade Gerenciada) que possui permissões excessivas.
- Abuso de permissões temporárias (por meio do PIM - **Privileged Identity Management**) ou retenção indevida de acesso elevado além do período de necessidade.
- Exploração de vulnerabilidades de configuração que permitem a um usuário com permissões de leitura ganhar permissões de escrita ou execução em recursos críticos.

Mitigações sugeridas:

Gerado em: 2025-09-28 23:12:14

Spoofing

- Impor a Autenticação Multifator (MFA) obrigatória para todos os usuários, especialmente aqueles com funções administrativas.
- Utilizar chaves FIDO2 ou Windows Hello for Business para credenciais que são resistentes a ataques de *pass-the-hash*.
- Configurar políticas de Acesso Condicional do Azure Entra ID que exijam conformidade do dispositivo e localização confiável.
- Monitorar e auditar mudanças nas configurações de federação (SAML - *Security Assertion Markup Language*) para identificar comprometimento de chaves.
- Habilitar o Bloqueio Inteligente para mitigar ataques de força bruta e evitar exaustão ou fadiga de MFA.
- Usar a Proteção de Senha do Azure Entra ID para proibir o uso de senhas fracas ou vazadas.
- Violação de Dados/Integridade
- Usar o Gerenciamento de Identidade Privilegiada (PIM) para acesso just-in-time (JIT) para modificações de políticas de segurança.
- Aplicar o princípio do privilégio mínimo (PoLP) através do Controle de Acesso Baseado em Função (RBAC - *controle de acesso baseado em função (RBAC)*).
- Proteger e assinar digitalmente *templates* de Infraestrutura como Código (IaC) para impedir a injeção de *backdoors*.
- Implantar políticas de Bloqueio de Recursos (bloqueios de recursos) em grupos de gerenciamento e subscrições críticas.
- Configurar alertas em tempo real no Microsoft Sentinel para qualquer alteração em funções RBAC de alto privilégio.
- Requerer uma aprovação de fluxo de trabalho para alterações em atributos críticos de identidade dentro do Azure Entra ID.

Repudiation

- Garantir a ingestão de logs de atividade detalhados de todos os administradores globais no Microsoft Sentinel para análise.
- Implementar a retenção longa de logs de auditoria em contas de armazenamento imutáveis para evitar modificação ou exclusão.
- Limitar as permissões de exclusão de logs a apenas contas de serviço de emergência estritamente monitoradas.
- Habilitar a trilha de auditoria para todas as ativações de função através do Gerenciamento de Identidade Privilegiada (PIM).
- Configurar o Azure Policy para impor configurações de diagnóstico e registro em todos os recursos novos.

Information Disclosure

- Impor o uso da Segurança da Camada de Transporte (TLS - *Transport Layer Security*) versão 1.2 ou superior em todos os *endpoints* públicos e internos.
- Armazenar todos os segredos, chaves e *tokens* de acesso exclusivamente no Azure Key Vault.
- Utilizar ferramentas de varredura de segredos em *pipelines* de desenvolvimento para evitar a divulgação acidental em código.
- Aplicar filtros e escopos granulares ao usar a API Microsoft Graph para restringir a exposição de dados de identidade.
- Revisar e refinar o Controle de Acesso Baseado em Função (RBAC) para acesso a *storage accounts* e bases de dados sensíveis.

Denial of Service

- Habilitar o Azure DDoS Protection Standard nos *front-ends* de aplicação e redes virtuais.
- Configurar o Bloqueio Inteligente no Azure Entra ID para limitar a taxa de tentativas de *login* malsucedidas.
- Implementar limitação de taxa (limitação de taxa) e *firewall* de aplicação (WAF) nos *gateways* de tráfego.
- Definir limites de gastos (Spending Limits) ou cotas de consumo em subscrições para serviços de computação com custo elevado.
- Utilizar autoscaling e balanceadores de carga para garantir a resiliência e disponibilidade de recursos críticos.

Elevation of Privilege

- Exigir a ativação just-in-time (JIT) de todas as funções elevadas através do Gerenciamento de Identidade Privilegiada (PIM).
- Auditar regularmente e remover permissões excessivas ou não utilizadas de identidades de serviço (*Service Principal*) e Identidades Gerenciadas.

Gerado em: 2025-09-28 23:12:14

- Aplicar o Controle de Acesso Baseado em Função (RBAC) de maneira estrita para impedir a atribuição de funções a si mesmo.
- Implementar revisões de acesso periódicas para certificar que as permissões temporárias foram revogadas após o uso.
- Utilizar políticas para restringir a criação e modificação de atribuições de função a um conjunto limitado de usuários aprovados.

Amazon SES

Análise STRIDE:

Spoofing

- Representação (Spoofing) (Falsificação de Identidade)
- Injeção de conteúdo malicioso (*scripts* ou HTML nocivo) nos modelos de e-mail utilizados pela aplicação, resultando em ataques de *phishing* ou comprometimento do lado do cliente.

Tampering

- Tentativa de envio de mensagens utilizando domínios não verificados ou sem a correta configuração de autenticação por chave (DKIM - *DomainKeys Identified Mail*) no DNS.
- Exploração de configurações DNS incorretas (como um registro SPF - *Sender Policy Framework* mal configurado) que permite que terceiros enviem e-mails em nome da organização.
- Violação de Integridade (Tampering) (Violação de Dados)
- Modificação não autorizada do conteúdo do e-mail (links, corpo da mensagem) após a chamada de envio, mas antes de sua entrega final ao destinatário.
- Alteração dos registros de rastreamento de clique ou abertura, armazenados em serviços de armazenamento do Azure, para manipular métricas de campanha.
- Modificação das listas de supressão (listas negras) para permitir que endereços previamente rejeitados recebam e-mails, violando políticas de conformidade.

Repudiation

- Falta de rastreamento (log) adequado das chamadas de interface de programação de aplicações (API) feitas por identidades gerenciadas no Azure para iniciar o envio de mensagens ou alterar configurações.
- Negação por parte de um usuário com permissão de acesso de ter realizado uma alteração nas políticas de envio (por exemplo, aumento da cota de envio diária).
- Ausência de trilhas de auditoria imutáveis que provem qual conta de serviço ou principal de segurança no Azure executou uma ação crítica de configuração de domínio.
- Impossibilidade de provar que um e-mail específico foi enviado com sucesso e aceito pelo servidor do destinatário, devido à falha na coleta e retenção de eventos de entrega.
- Divulgação de Informação (Divulgação de Informação)
- Vazamento de listas de destinatários ou do conteúdo de mensagens devido a configurações incorretas de registro de eventos em serviços de armazenamento do Azure acessíveis publicamente.
- Exposição de chaves de API ou segredos do serviço de e-mail armazenados de forma insegura em repositórios de código ou variáveis de ambiente de aplicações Azure.
- Divulgação de informações de diagnóstico e saúde do ambiente (como taxas de rejeição ou reputação de remetente) que podem ser usadas por atacantes para planejar ataques direcionados.
- Armazenamento inadequado de modelos de e-mail contendo Informação Pessoalmente Identificável (PII), sem a devida criptografia em repouso.

Information Disclosure

- Falsificação do endereço de remetente (*header* "De") em e-mails transacionais enviados por um recurso Azure cujas credenciais foram roubadas.

Denial of Service

- Comprometimento das chaves de API ou dos segredos de conexão utilizados pela aplicação (por exemplo, hospedada em um Serviço de Aplicação Azure) para interagir com o serviço de envio.
- Ataque de negação de serviço distribuída (DDoS - *Distributed Negação de Serviço*) que sobrecarrega a infraestrutura de rede que interage com o serviço de e-mail, impedindo a submissão de novas mensagens.

Gerado em: 2025-09-28 23:12:14

- Envio massivo e rápido de mensagens que atinja as cotas de envio definidas na conta, bloqueando a capacidade de enviar e-mails transacionais críticos para a operação.
- Execução de um ataque de lista de rejeição forçada, enviando e-mails para endereços inexistentes em volume alto o suficiente para degradar a reputação do remetente e suspender o serviço.
- Consumo excessivo de recursos (*limitação de taxa*) da aplicação cliente Azure devido a um *loop* de envio descontrolado, impedindo que outros serviços legítimos utilizem a mesma infraestrutura.

Elevation of Privilege

- Exploração de fraquezas no Controle de Acesso Baseado em Função (RBAC - *controle de acesso baseado em função (RBAC)*) do Azure que permite que uma entidade de serviço com poucas permissões gerencie as identidades de envio do domínio.
- Comprometimento de uma identidade gerenciada no Azure que possui permissões excessivas (*princípio do menor privilégio violado*) para alterar políticas de segurança críticas do serviço de e-mail.
- Obtenção de acesso a chaves mestras de criptografia utilizadas para proteger dados em repouso por meio de escalonamento de privilégios em um cofre de chaves (Key Vault) associado.
- Um usuário com permissão apenas para "visualizar" consegue obter acesso de "gravação" para alterar os *endpoints* de notificação de eventos (por exemplo, um Tópico do Barramento de Serviço).

Mitigações sugeridas:

Spoofing

- Representação (Spoofing) (Falsificação de Identidade)
- Utilizar Identidades Gerenciadas do Azure para autenticação de aplicações (como Serviço de Aplicação) no serviço de envio, eliminando a necessidade de segredos.

Tampering

- Configurar registros SPF (*Sender Policy Framework*) e DKIM (*DomainKeys Identified Mail*) válidos e estritos para o domínio remetente no DNS.
- Implementar DMARC (*Domain-based Message Authentication Reporting and Conformance*) para instruir os destinatários sobre como tratar falhas de autenticação.
- Armazenar todas as chaves de API e segredos de conexão exclusivamente no Azure Key Vault.
- Forçar a validação da origem do remetente e o uso de domínios verificados dentro da infraestrutura de e-mail do Azure.
- Violação de Integridade (Tampering) (Violação de Dados)
- Aplicar validação rigorosa de entrada e higienização (*sanitização*) de todo conteúdo dinâmico ou HTML injetado nos modelos de e-mail.
- Implementar políticas de imutabilidade (*Worm*) no Armazenamento de Blobs do Azure para proteger registros de rastreamento contra alterações.
- Aplicar o Controle de Acesso Baseado em Função (RBAC) do Azure estrito às operações que modificam listas de supressão ou modelos de e-mail.
- Utilizar *hashes* de conteúdo nas cargas úteis antes do envio e verificar a integridade antes do processamento.
- Garantir que os modelos de e-mail armazenados sejam protegidos e atualizados apenas através de processos automatizados de integração contínua/entrega contínua (CI/CD).

Repudiation

- Ativar o Azure monitorar Activity Log e o Log Analytics para rastrear todas as chamadas de interface de programação de aplicações (API) de configuração e gerenciamento.
- Garantir que as ações críticas de envio e configuração sejam rastreadas até a Identidade Gerenciada ou principal de segurança específica do Azure Active Directory.
- Configurar a exportação dos logs de auditoria para um serviço de armazenamento com retenção bloqueada ou para o Azure Sentinel para trilhas imutáveis.
- Coletar e reter logs de eventos de entrega (confirmação, rejeição, aceite do servidor) providos pelo serviço de e-mail para provar o sucesso do envio.
- Exigir autenticação multifator para todos os usuários com permissões para modificar políticas ou cotas de envio do serviço.
- Divulgação de Informação (Divulgação de Informação)

Gerado em: 2025-09-28 23:12:14

- Remover chaves de API de variáveis de ambiente ou repositórios de código e referenciá-las apenas através do Azure Key Vault.
- Restringir o acesso aos painéis de diagnóstico e relatórios de reputação do remetente apenas a identidades com necessidade de conhecimento.
- Configurar listas de controle de acesso (ACLs) ou *endpoints* de serviço do Azure nos serviços de armazenamento para garantir que os logs não sejam acessíveis publicamente.
- Criptografar todos os dados confidenciais em repouso, incluindo listas de destinatários e modelos de e-mail, utilizando chaves gerenciadas pelo cliente (CMK).
- Aplicar rótulos de confidencialidade do Azure Information Protection aos dados contendo Informação Pessoalmente Identificável (PII).

Denial of Service

- Utilizar o Azure DDoS Protection (*Distributed Negação de Serviço*) para proteger os *endpoints* públicos de aplicações Azure que interagem com a API de envio.
- Implementar *limitação de taxa* e cotas de uso na aplicação cliente Azure para prevenir *loops* descontrolados de envio (ataque de *limitação de taxa*).
- Monitorar ativamente as métricas de cotas de envio e configurar alertas no Azure monitorar para notificação antes que os limites sejam atingidos.
- Aplicar o padrão *Circuit Breaker* (Disjuntor) no código da aplicação cliente para interromper tentativas de envio em caso de erros persistentes.
- Validar a sintaxe dos endereços de e-mail e utilizar serviços de validação de lista para mitigar ataques de lista de rejeição forçada que degradam a reputação.

Elevation of Privilege

- Adotar rigorosamente o princípio do menor privilégio, concedendo apenas as permissões mínimas necessárias no Controle de Acesso Baseado em Função (RBAC).
- Implementar acesso just-in-time (JIT) e Gerenciamento de Acesso Privilegiado (PIM) para funções administrativas críticas do serviço de e-mail.
- Restringir o acesso a chaves mestras de criptografia no Azure Key Vault usando firewalls de *endpoint* e políticas de acesso específicas.
- Criar funções RBAC personalizadas no Azure para separar claramente as permissões de "visualizar" das permissões de "gravação" ou administração.
- Realizar auditorias periódicas e automáticas das atribuições de funções RBAC e das permissões concedidas às Identidades Gerenciadas.

AWS Backup

Análise STRIDE:

Spoofing

- Falsificação de Identidade (Representação (Spoofing))
- Assunção de identidade por um recurso [resource] não autorizado para se registrar como um recurso válido a ser protegido pelo plano de cópia de segurança.
- Comprometimento de um sistema de identidade (como o IAM - *Identity and Access Management* - gerenciamento de identidade e acesso) que permite a um ator mal-intencionado se passar por um administrador de cópia de segurança.

Tampering

- Uso indevido de credenciais de serviço (funções de execução) para modificar ou desabilitar políticas de retenção de cópia de segurança [backup].
- Comprometimento de chaves de acesso que permitem a criação de cópias de segurança não autorizadas em contas ou cofres externos à organização.
- Violação de Integridade (Violação de Integridade (Tampering))
- Alteração dos metadados dos pontos de recuperação armazenados, tornando a restauração incorreta ou introduzindo dados maliciosos durante o processo de *recovery*.

Gerado em: 2025-09-28 23:12:14

- Modificação das políticas de ciclo de vida para encurtar o período de retenção, resultando na exclusão prematura e não autorizada de dados críticos.
- Manipulação das regras de criptografia (por exemplo, alterando chaves de Serviço de Gerenciamento de Chaves [KMS]) para impedir o acesso aos dados ou comprometer a segurança futura.
- Injeção de código ou configuração maliciosa no plano de cópia de segurança antes da execução, afetando a consistência dos dados que serão armazenados no cofre.

Repudiation

- Falta de rastreamento robusto e imutável (registros de auditoria) sobre a exclusão de cofres de cópia de segurança ou pontos de recuperação críticos por parte de um usuário administrativo.
- Ausência de trilhas de auditoria que correlacionem de forma inequívoca a modificação de políticas de retenção com o usuário ou função de serviço que iniciou a mudança.
- Incapacidade de provar qual usuário ou sistema iniciou um trabalho de restauração (job de *restore*), especialmente em ambientes de emergência onde a ação é crítica.
- Divulgação de Informação (Divulgação de Informação)
- Configuração incorreta que permite que cópias de segurança sejam armazenadas em cofres sem criptografia em repouso (utilizando chaves gerenciadas pelo cliente ou pelo provedor de nuvem).
- Acesso não autorizado a cofres de cópia de segurança (vaults) devido a permissões excessivamente permissivas no gerenciamento de acesso (por exemplo, políticas de acesso baseadas em recursos que não são restritivas o suficiente).
- Exposição de informações sensíveis durante a replicação entre regiões se o tráfego de cópia de segurança não for tratado em conformidade com padrões de segurança específicos (embora o tráfego interno do provedor de nuvem seja geralmente protegido).
- Divulgação de dados através da recuperação acidental ou proposital em um ambiente de destino não seguro.

Denial of Service

- Exclusão massiva de pontos de recuperação de forma automatizada ou manual, impedindo que a organização realize qualquer operação de restauração de desastre.
- Criação de um número excessivo de trabalhos de cópia de segurança ou restauração que sobrecarregam os *endpoints* da API, esgotando os limites de serviço da conta (limitação de taxa).
- Ataque de Negação de Serviço Distribuído (DDoS - *Distributed Negação de Serviço*) direcionado aos serviços de cópia de segurança, inviabilizando operações de gestão de políticas ou acesso aos dados.
- Impedimento da restauração de dados críticos devido à suspensão ou exclusão das chaves de criptografia (KMS) associadas aos cofres de cópia de segurança.

Elevation of Privilege

- Aproveitamento de uma função de serviço (Role) configurada para cópia de segurança que possua permissão de "passagem de função" para obter acesso a outros serviços não relacionados.
- Exploração de permissões de gestão de políticas para conceder a si próprio direitos de exclusão administrativa ou alteração de cofres imutáveis.
- Um usuário com permissão de restauração obtendo acesso administrativo irrestrito ao sistema de destino restaurado, escalando privilégios nesse novo ambiente.
- Abuso do acesso de leitura aos cofres para obter informações de configuração que possam ser usadas para escalonar para privilégios de escrita ou administração total do serviço.

Mitigações sugeridas:

Spoofing

- Falsificação de Identidade (Representação (Spoofing))
- Utilize Identidades Gerenciadas (Identidade Gerenciada) para acesso de recursos, removendo a necessidade de credenciais estáticas.
- Exija Autenticação Multifator (MFA) para todas as contas administrativas que gerenciam cofres de recuperação.
- Monitore o Azure AD (Diretório Ativo) e configurar alertas para anomalias na tentativa de assunção de identidade (Role Assumption).

Tampering

Gerado em: 2025-09-28 23:12:14

- Aplique o Azure Policy para impedir o registro de recursos desconhecidos para proteção de cópia de segurança.
- Violação de Integridade (Violação de Integridade (Tampering))
- configurar o Bloqueio de Imutabilidade (Immutability Lock) no cofre de recuperação para proteger pontos de recuperação e políticas.
- Utilize Bloqueios de Recurso (bloqueios de recursos) de "Somente Leitura" (Read-Only) nos cofres de cópia de segurança e nos *Key Vaults*.
- Implemente o Azure Policy para auditar e impor políticas de retenção mínimas e configurações de criptografia padrão.
- Habilite a Proteção de Exclusão Suave (Soft Delete Protection) no cofre de cópia de segurança para recuperação de exclusões acidentais ou maliciosas.

Repudiation

- Encaminhe todos os Registros de Atividades (Activity Logs) para um espaço de trabalho Log Analytics imutável ou para um sistema SIEM.
- configurar a retenção de logs de auditoria por um período estendido e inviolável em conformidade com requisitos regulatórios.
- Utilize o Azure monitorar para criar alertas sobre modificações de políticas de retenção ou exclusões de pontos de recuperação críticos.
- Assegure que os logs de auditoria correlacionem inequivocamente o principal de segurança (usuário ou serviço) que iniciou a ação.
- Divulgação de Informação (Divulgação de Informação)
- Exija a Criptografia Gerenciada pelo Cliente (CMK) para todos os cofres de cópia de segurança que armazenam dados confidenciais.
- Restrinja o acesso à rede dos cofres usando *Private Endpoints* (Pontos de Extremidade Privados) e desabilite o acesso público.
- Utilize o Azure Policy para impedir a criação de cofres de cópia de segurança que não apliquem criptografia em repouso.
- Implemente RBAC de menor privilégio para limitar o acesso de leitura aos metadados e conteúdos dos cofres.
- Garanta que os dados restaurados sejam direcionados apenas a ambientes de destino classificados e seguros, usando permissões restritas.

Information Disclosure

- Aplique segregação de funções, separando o controle das políticas de cópia de segurança do gerenciamento das chaves de criptografia.

Denial of Service

- Ative a Exclusão Suave (Soft Delete) no Cofre de Recuperação e nos *Key Vaults* para prevenir a exclusão total imediata.
- Implemente RBAC rigoroso para garantir que o administrador de cópia de segurança não possa excluir ou suspender as chaves de criptografia (KMS).
- Monitore os limites de serviço e as taxas de solicitação (limitação de taxa) para detectar atividades anômalas ou tentativas de sobrecarga de API.
- Utilize o Azure Front Door ou serviços de mitigação DDoS (Negação de Serviço Distribuído) para proteger *endpoints* de gerenciamento de cópia de segurança.
- configurar um plano de recuperação de chaves de criptografia para garantir a disponibilidade de dados em caso de falha do Key Vault primário.

Elevation of Privilege

- Implemente RBAC (Controle de Acesso Baseado em Função) com o princípio de privilégio mínimo para funções de serviço de cópia de segurança.
- Revise Funções Personalizadas para eliminar permissões de "passagem de função" ou atribuições de acesso excessivamente amplas.
- Utilize o Gerenciamento de Identidade Privilegiada (PIM) para aplicar privilégios JIT (just-in-time) para tarefas de alto risco.
- Implemente a separação de deveres, garantindo que o restaurador de dados não tenha acesso administrativo irrestrito ao sistema de destino restaurado.

Gerado em: 2025-09-28 23:12:14

- Restrinja a capacidade de um usuário com privilégio de leitura de acessar ou modificar políticas de cópia de segurança ou chaves.
- Use o Azure Policy para auditar e bloquear atribuições de RBAC que combinem privilégios de exclusão e gestão de políticas.

Grupo de Auto Scaling da AWS

Análise STRIDE:

Spoofing

- Um ator malicioso tenta personificar a identidade gerenciada (MI) do *Virtual Machine Scale Set* (VMSS) para obter tokens de acesso e interagir com outros serviços Azure.

Tampering

- Falsificação
- Ataque de fornecimento (supply chain) onde um invasor falsifica a origem da imagem personalizada de máquina virtual, injetando uma versão comprometida.
- Violação
- Modificação não autorizada das políticas de escalonamento automático (ex.: alterar o limite máximo de instâncias para exaurir o orçamento ou o limite de subscrição).
- Um atacante viola a integridade do modelo ARM (Azure Resource Manager) ou do *script* de inicialização (Custom Data) para novos nós, introduzindo código malicioso.
- Alteração dos parâmetros de verificação de integridade (health check) do grupo de escala para impedir que instâncias não saudáveis sejam substituídas ou removidas, comprometendo a disponibilidade.
- Violação das regras do Grupo de Segurança de Rede (NSG) associado ao Conjunto de Escala para abrir portas de gerenciamento indevidas.

Repudiation

- Ausência de trilhas de auditoria detalhadas no Azure monitorar e *Activity Log* que registrem qual identidade (usuário ou serviço) modificou os parâmetros de capacidade mínima ou máxima do VMSS.
- Falha em exigir e registrar assinaturas digitais ou confirmações para alterações críticas no *template* de implantação do Conjunto de Escala.
- Um administrador remove uma política de escalonamento complexa, e os registros não fornecem evidências suficientes para determinar se a ação foi intencional ou acidental.
- Exclusão de logs de implantação de máquinas virtuais sem retenção adequada, impossibilitando a rastreabilidade da imagem utilizada no *deploy*.
- Divulgação de Informação
- O *template* de definição do Conjunto de Escala (VMSS) expõe inadvertidamente dados sensíveis, como *tokens* de acesso ou segredos de conexão em texto simples.
- Métricas de escalonamento utilizadas pelo Azure monitorar (ex.: uso interno da aplicação, latência do banco de dados) são configuradas para serem acessíveis publicamente.
- Configuração incorreta do registro de diagnóstico que permite a exportação de informações detalhadas sobre a topologia da rede virtual (VNet) ou endereçamento interno.
- Informações sobre a região e SKU de *hardware* utilizada pelo VMSS são facilmente enumeradas por atacantes que visam explorar vulnerabilidades específicas de máquina.

Denial of Service

- Um processo interno não autorizado se passa pelo serviço de saúde do Azure (Health Probe) para relatar falsamente a indisponibilidade de instâncias saudáveis, forçando o *scale-down*.
- Manipulação de métricas (metric flooding) para forçar o escalonamento excessivo do VMSS, levando à exaustão dos limites da subscrição ou a um *Negação de Serviço Econômico* (custos proibitivos).
- Configuração incorreta ou deleção do repositório da imagem da máquina virtual (Azure Compute Gallery) que impede que novas instâncias sejam provisionadas, resultando em falha no *scale-out*.
- Um atacante obtém acesso para definir o limite mínimo de instâncias para zero, causando um *scale-down* prematuro e indisponibilidade do serviço.

Gerado em: 2025-09-28 23:12:14

- Sobrecarga da API do *Azure Resource Manager* (ARM) por um atacante que tenta repetidamente criar ou modificar instâncias, impedindo o gerenciamento legítimo do VMSS.

Elevation of Privilege

- Exploração de configurações fracas de *Azure controle de acesso baseado em função (RBAC)* (RBAC) que permitem a uma entidade de baixo privilégio assumir o controle da definição do grupo de escala.
- Um usuário com permissão de "Leitura" no VMSS explora uma falha na delegação de *Azure RBAC* para obter a capacidade de modificar as políticas de escalonamento.
- Exploração de vulnerabilidades em extensões de máquinas virtuais (VM Extensions) ou no agente do Azure, executadas durante o provisionamento, para obter acesso de *root*/sistema nas novas instâncias.
- O comprometimento da entidade de serviço (Service Principal) utilizada para gerenciar o grupo de escala permite ao atacante utilizar essas credenciais para acessar e manipular outros recursos Azure.
- Manipulação das políticas de acesso do *Key Vault* vinculado ao VMSS, permitindo que as novas instâncias leiam segredos que não deveriam ter acesso.

Mitigações sugeridas:

Spoofing

- Implemente o princípio do menor privilégio (PoLP) para todas as Identidades Gerenciadas (MI) utilizadas pelo Conjunto de Escala.
- configurar o Acesso Condicional (Conditional Access) para identidades que gerenciam as definições do VMSS.

Tampering

- Falsificação
- Utilize o Azure Policy para impor que as imagens de máquina virtual (VM) provenham apenas da Galeria de Computação do Azure ou de fontes assinadas.
- Garanta que a comunicação do *Health Probe* utilize autenticação mútua (TLS mútuo) ou um certificado para validação de origem.
- Violação
- Utilize *templates* do Azure Resource Manager (ARM) protegidos por controle de versão e revisão de código obrigatória (*branch protection*).
- Implemente a imutabilidade do código fonte usando *checksums* validados no *script* de inicialização (*Custom Data*).
- configurar o Bloqueio de Recursos (bloqueios de recursos) no Conjunto de Escala ou no Grupo de Recursos para evitar deleções ou modificações críticas.
- Exija aprovação multifatorial ou revisões de pares para todas as alterações que modifiquem as políticas de escalonamento automático.

Repudiation

- Ative a retenção estendida (Long-Term Retention) dos logs do Azure Activity Log e *Diagnostic Settings*.
- Encaminhe todos os logs de gerenciamento (control plane) para o Azure Log Analytics com política de imutabilidade (WORM - Escreva Uma Vez, Leia Muitas).
- Imponha que todas as implantações de *template* sejam rastreadas através de uma esteira de CI/CD (*pipeline* de integração e entrega contínua) que registre o usuário.
- configurar alertas no Azure monitorar para notificar imediatamente sobre alterações na capacidade mínima ou máxima do VMSS.
- Utilize *Resource Graph* ou Inventário do Azure para rastrear e auditar o histórico de alterações da imagem de máquina virtual (*source image*).
- Divulgação de Informação
- Garanta que todos os segredos e *tokens* sejam injetados nas VMs em tempo de execução usando o Azure Key Vault e Identidades Gerenciadas (MI).
- Utilize o Serviço de Configuração de Aplicação do Azure para separar dados de configuração sensíveis do *template* ARM.
- Aplique o Controle de Acesso Baseado em Função (RBAC) para limitar a quem pode visualizar métricas detalhadas de escalonamento no Azure monitorar.

Gerado em: 2025-09-28 23:12:14

- configurar os Logs de Diagnóstico para mascarar ou omitir endereços IP internos e detalhes da topologia da Rede Virtual (VNet).
- Use o Azure Front Door ou o Application Gateway para ocultar a infraestrutura de *backend* (SKUs e regiões) do acesso público direto.

Denial of Service

- Defina regras do Grupo de Segurança de Rede (NSG) seguindo o princípio de "negar tudo por padrão", permitindo apenas o tráfego essencial.
- Defina limites máximos de escalonamento rigorosos (Max Instance Count) para evitar o esgotamento do limite da subscrição e custos proibitivos.
- Monitore e defina limites de consumo (budget alerts) no Azure Cost Management para alertar sobre *Negação de Serviço Econômico*.
- Utilize o *limitação de taxa* (limitação de taxa) e o *Resource Governor* para proteger a API do ARM contra sobrecarga de requisições.
- configurar limites mínimos de instância (>0) para serviços críticos e impeça que administradores de baixo privilégio os alterem.
- Utilize replicação de imagens em várias zonas de disponibilidade ou regiões para garantir a resiliência do fornecimento da imagem (*source image*).

Elevation of Privilege

- Defina papéis de Controle de Acesso Baseado em Função (RBAC) customizados para impedir que papéis de baixo privilégio modifiquem a capacidade.
- Implemente Acesso just-in-time (JIT) e Gerenciamento de Identidade Privilegiada (PIM) para funções administrativas críticas do VMSS.
- Audite e restrinja as permissões da Entidade de Serviço (Service Principal) para que afetem apenas o escopo mínimo de recursos.
- Aplique o Azure Security Benchmark (ASB) e o Azure Defender para Gerenciamento de Vulnerabilidades nas VMs provisionadas.
- Use o Controle de Acesso Baseado em Função (RBAC) do Azure Key Vault, em vez de políticas de acesso legado, para gerenciar segredos.
- Bloqueie a execução de *scripts* com privilégios de *root*/sistema via *Custom Script Extension* em novas instâncias.

Sub-rede Privada da AWS

Análise STRIDE:

Spoofing

- A falsificação de identidade de um princípio de serviço (Service Principal) comprometido, permitindo que ele se passe por um serviço legítimo para acessar *endpoints* internos do Azure.

Tampering

- Falsificação (Representação (Spoofing))
- Um host comprometido tenta falsificar o endereço IP (Internet Protocol) de uma máquina virtual confiável dentro da sub-rede para burlar regras do NSG (Grupo de Segurança de Rede).
- Tentativas de manipulação do DNS (Sistema de Nomes de Domínio) privado da sub-rede para redirecionar o tráfego interno para um servidor malicioso.
- Violação de Integridade (Violação de Integridade (Tampering))
- Modificações não rastreadas nas Tabelas de Rotas ou nos NSGs (Grupos de Segurança de Rede) associados à sub-rede, alterando intencionalmente o fluxo de tráfego autorizado.
- Comprometimento de uma máquina virtual que hospeda um aplicativo, permitindo a modificação não autorizada de dados persistentes ou configurações do sistema operacional.
- Ataques de "homem no meio" (*man-in-the-middle*) dentro da VNet (Rede Virtual) que alteram o conteúdo das mensagens trocadas entre serviços internos não criptografados.

Repudiation

Gerado em: 2025-09-28 23:12:14

- Alteração ou exclusão de logs de diagnóstico e auditoria armazenados, dificultando a detecção de atividades maliciosas na sub-rede.
- Falta de logs de auditoria detalhados (como Azure monitorar Logs) para registrar qual identidade do usuário ou processo realizou alterações nas políticas de acesso da sub-rede.
- Uso de contas de serviço compartilhadas ou chaves de acesso genéricas que impedem a rastreabilidade individual das ações administrativas sobre os recursos de rede.
- Ausência de rastreamento de conexões ou logs de fluxo do NSG, impedindo a determinação da origem exata de uma comunicação interna maliciosa.
- Divulgação de Informação (Divulgação de Informação)
- Exposição acidental de dados internos para a internet pública devido à configuração incorreta de serviços de *endpoint* que deveriam utilizar o Azure Private Link.
- Comunicação não criptografada (sem TLS - Segurança da Camada de Transporte) entre microsserviços dentro da sub-rede, permitindo que *sniffing* revele dados em trânsito.
- Configuração incorreta de *storage accounts* (contas de armazenamento) que aceitam conexões de sub-redes ou VNets não autorizadas.
- Vazamento de metadados internos ou chaves de acesso através de logs de diagnóstico mal configurados ou acessíveis publicamente.

Information Disclosure

- Utilização indevida de chaves de acesso ou tokens de serviço roubados para personificar um aplicativo legítimo dentro da VNet (Rede Virtual).

Denial of Service

- Esgotamento de recursos da sub-rede causada por uma sobrecarga de tráfego interno (por exemplo, um loop de tráfego ou um recurso infectado gerando alto volume de dados).
- Saturação da banda de rede disponível para a VNet (Rede Virtual) causada por um ataque volumétrico (embora a mitigação seja global, o efeito é sentido na sub-rede).
- Configuração excessivamente restritiva ou falha de um NVA (Appliance Virtual de Rede) que bloqueia ou atrasa o tráfego legítimo, tornando os serviços inacessíveis.
- Exaustão das conexões ou portas disponíveis na NAT (Tradução de Endereços de Rede) de saída, impedindo que os recursos internos se comuniquem com o exterior.

Elevation of Privilege

- Atribuições excessivas no controle de acesso baseado em função (RBAC - controle de acesso baseado em função (RBAC)) que permitem a usuários de baixo privilégio modificar as configurações da VNet ou NSGs.
- Exploração de vulnerabilidades em serviços de rede ou aplicativos para obter acesso de nível de administrador em máquinas virtuais na sub-rede (movimentação lateral).
- Exploração de permissões de identidade gerenciada (Managed Identity) mal configuradas, permitindo que um aplicativo use uma identidade de maior privilégio para acessar serviços críticos.
- Comprometimento de um segredo armazenado no Azure Key Vault que concede acesso irrestrito a credenciais de alto privilégio usadas pelos recursos da sub-rede.

Mitigações sugeridas:

Spoofing

- Implementar Autenticação Multifator (MFA) e Acesso Condicional para Princípios de Serviço.

Tampering

- Falsificação
- Utilizar Zonas DNS Privadas do Azure e restringir modificações via RBAC (Controle de Acesso Baseado em Função).
- Configurar Azure Firewall ou NSGs (Grupos de Segurança de Rede) para inspeção estrita de IP de origem.
- Exigir o uso de Assinaturas de Acesso Compartilhado (SAS) limitadas em vez de chaves de conta.
- Garantir que os *endpoints* internos utilizem certificados digitais confiáveis para autenticação mútua.
- Violação de Integridade
- Aplicar políticas do Azure (Azure Policy) para auditar e impor configurações imutáveis nos NSGs e Tabelas de Rotas.

Gerado em: 2025-09-28 23:12:14

- Utilizar Azure Disk Encryption para proteger dados persistentes contra modificação em VMs (Máquinas Virtuais) comprometidas.
- Exigir o uso de TLS (Segurança da Camada de Transporte) 1.2 ou superior para toda a comunicação de serviço para serviço.
- Restringir o acesso de administração (*shell* ou área de trabalho remota) às máquinas virtuais via JIT (just-in-time) VM Access.
- Utilizar *containers* e armazenamento imutável para aplicativos sensíveis a violações de conteúdo.

Repudiation

- Configurar a retenção imutável e bloqueios de exclusão nos logs do Azure monitorar e contas de armazenamento.
- Habilitar as Configurações de Diagnóstico completas (Identity, UserPrincipalName) para todos os recursos de rede críticos.
- Substituir contas de serviço compartilhadas por Identidades Gerenciadas (Identidade Gerenciada) para rastreamento exclusivo de processos.
- Ativar e analisar Logs de Fluxo do NSG (Grupo de Segurança de Rede) no Azure Network Watcher.
- Exigir a ativação de papéis privilegiados através do Azure PIM (Gerenciamento de Identidade Privilegiada) com justificativa obrigatória.
- Implementar o registro de comandos na linha de comando e atividades do PowerShell via Azure Automation.
- Divulgação de Informação
- Utilizar o Azure Private Link para garantir que o acesso aos serviços PaaS (Plataforma como Serviço) ocorra exclusivamente pela VNet (Rede Virtual).
- Forçar a criptografia ponta a ponta (mTLS) para a comunicação interna de microserviços.
- Restringir o acesso a Contas de Armazenamento (Storage Accounts) apenas a sub-redes autorizadas usando Service Endpoints.
- Garantir que o acesso aos logs de diagnóstico (Azure monitorar Logs) seja estritamente restrito por RBAC.
- Habilitar a criptografia em repouso por padrão (Azure Storage Encryption, Disk Encryption).
- Remover informações sensíveis (como chaves) de logs de diagnóstico usando filtragem ou mascaramento.

Information Disclosure

- Implementar o rodízio regular de chaves de acesso e tokens usando o Azure Key Vault.

Denial of Service

- Habilitar a Proteção contra DDoS (Negação de Serviço Distribuída) do Azure Standard na VNet.
- Utilizar Azure NAT Gateway para fornecer IPs de saída escaláveis e evitar o esgotamento de portas SNAT (Tradução de Endereço de Rede de Origem).
- Segmentar a VNet usando NSGs ou Azure Firewall para limitar a propagação de tráfego interno malicioso ou *loops*.
- Implementar redundância (Alta Disponibilidade) e monitoramento de saúde para NVAs (Appliance Virtual de Rede) críticos.
- Aplicar limites de taxa (rate limits) e *limitação de taxa* em APIs de *endpoints* internos.
- Monitorar ativamente as métricas de utilização de rede e conexões para detectar anomalias rapidamente.

Elevation of Privilege

- Aplicar rigorosamente o princípio do menor privilégio no RBAC (Controle de Acesso Baseado em Função) em nível de sub-rede.
- Isolar VMs em sub-redes separadas e usar just-in-time (JIT) VM Access para conexões administrativas.
- Auditar e limitar estritamente as permissões atribuídas às Identidades Gerenciadas (Identidade Gerenciada).
- Exigir o uso de Identidades Gerenciadas em vez de segredos e restringir o acesso ao Azure Key Vault via VNet Service Endpoint.
- Utilizar o Azure Security Center (Defender for Cloud) para monitorar configurações incorretas e vulnerabilidades do sistema operacional.
- Implementar privilégios temporários usando o Azure PIM (Gerenciamento de Identidade Privilegiada) para acesso elevado.

Application Load Balancer (ALB)

Gerado em: 2025-09-28 23:12:14

Análise STRIDE:

Spoofing

- Comprometimento das Chaves de Acesso ou Identidades Gerenciadas utilizadas pelo balanceador de carga para se comunicar com o *backend* (servidores de aplicação).
- Falsificação da identidade do servidor de *backend* devido a uma falha na validação da cadeia de confiança dos certificados SSL/TLS.

Tampering

- Falsificação
- Manipulação de cabeçalhos HTTP (`Host` header Representação (Spoofing)) que o balanceador de carga utiliza para determinar o roteamento da requisição.
- Um cliente malicioso se passando por um servidor de saúde (*health probe*) para injetar dados ou coletar informações sobre o estado do *backend*.
- Violação de Integridade (Tampering) (Adulteração)
- Modificação das regras de *WAF (Firewall de Aplicação Web)* (WAF) por uma conta administrativa comprometida no painel de gerenciamento do Azure.
- Injeção de código malicioso (*SQL injection*, *Cross-Site Scripting* - XSS) nos parâmetros de requisição antes que o tráfego seja inspecionado ou criptografado novamente para o *backend*.
- Acesso e modificação não autorizados das configurações de *Listener Ports* ou *backend Pool* via API de gerenciamento do Azure.

Repudiation

- Incapacidade de provar quem modificou as regras de *traffic routing* (roteamento de tráfego) ou desabilitou o *WAF (Firewall de Aplicação Web)* (WAF) devido à falta de logs de auditoria detalhados (via Azure monitorar).
- Ausência de registro adequado sobre o endereço IP real do cliente, caso o cabeçalho `X-Forwarded-For` seja removido ou não seja configurado para registro.
- Falha em capturar logs de acesso de diagnóstico que demonstrem as regras específicas do WAF acionadas e o usuário responsável por tentar burlá-las.
- Um administrador que nega ter desativado o *logging* de diagnóstico do recurso de balanceamento de carga no Azure.
- Divulgação de Informação (Divulgação de Informações)
- Exposição de informações sobre a arquitetura de *backend* (como nomes de servidores, IPs internos ou tipos de tecnologia) através de mensagens de erro detalhadas ou códigos de redirecionamento.
- Vazamento de dados confidenciais (*cookies* de sessão, tokens) se o tráfego entre o balanceador de carga e os servidores de aplicação não for criptografado (conexões HTTP).
- Divulgação de chaves privadas ou certificados SSL/TLS armazenados no Cofre de Chaves do Azure (*Azure Key Vault*) devido a permissões de acesso excessivas concedidas ao recurso.
- Exposição de *banners* de versão do software ou *headers* HTTP que revelam informações de segurança sobre a infraestrutura do balanceador de carga.

Denial of Service

- Adulteração dos dados da requisição ou da resposta se a terminação TLS (Transport Layer Security) ocorrer sem a devida revalidação do *backend*.
- Inundação de requisições que esgotam a capacidade máxima de conexões e processamento de CPU do *Application Gateway*.
- Ataques de esgotamento de sessão SSL que sobrecarregam a capacidade de cálculo do balanceador de carga durante o *handshake* (aperto de mão) TLS.
- Configuração incorreta de *health probes* (sondas de saúde) que levam à remoção indevida de servidores saudáveis do *backend pool*, resultando em sobrecarga dos servidores restantes.
- Ataque Distribuído de Negação de Serviço (DDoS) que satura a rede e esgota os recursos do serviço, mesmo com a proteção de mitigação embutida do Azure.
- Configuração de *timeouts* (*tempo limite*) inadequados, causando longas esperas e esgotamento prematuro do *pool* de conexões.

Elevation of Privilege

- Exploração de vulnerabilidades no *WAF (Firewall de Aplicação Web)* (WAF) para burlar restrições de segurança e obter acesso com privilégio de aplicação ao *backend*.

Gerado em: 2025-09-28 23:12:14

- Um usuário com permissões de leitura no Controle de Acesso Baseado em Função (RBAC) que consegue obter acesso para modificar (privilegio de colaborador) as configurações críticas do balanceador de carga.
- Comprometimento de credenciais de serviço ou Identidades Gerenciadas que permitem acesso não autorizado a recursos de segurança adjacentes, como o Azure Key Vault.
- Configuração negligente do RBAC que permite que administradores com privilégios limitados desativem medidas de segurança cruciais, como o TLS de ponta a ponta.

Mitigações sugeridas:

Spoofting

- Utilizar Identidades Gerenciadas (Identidades que o Azure gerencia para recursos) com privilégios mínimos para acessar segredos no Cofre de Chaves.

Tampering

- Falsificação
- Configurar regras no WAF (Firewall de Aplicações Web) para sanitizar e validar o cabeçalho `Host` antes do roteamento da requisição.
- Restringir o acesso às sondas de saúde (*health probes*) utilizando grupos de segurança de rede (NSGs) baseados nos IPs internos do Azure para essa finalidade.
- Aplicar o Controle de Acesso Baseado em Função (RBAC) para segregar as permissões de modificação das regras do WAF (Firewall de Aplicações Web).
- Habilitar o WAF no modo Prevenção e garantir que as regras de *Core Rule Set* (CRS) estejam atualizadas para mitigar injeções (SQL, XSS).
- Habilitar o Bloqueio de Recursos (bloqueios de recursos) no Azure para proteger as configurações críticas de gerenciamento contra alterações não autorizadas.
- Utilizar a re-criptografia TLS (Transport Layer Security) do balanceador para garantir a integridade dos dados na comunicação com o *backend*.
- Exigir a revisão e aprovação de pares (quatro olhos) para todas as alterações na configuração de *Listener Ports* ou *backend Pool* via API.

Repudiation

- Habilitar logs de Atividade e Diagnóstico no Azure monitorar para rastrear todas as modificações de configuração administrativa.
- Garantir que o balanceador esteja configurado para preservar e registrar o cabeçalho `X-Forwarded-For` para obter o endereço IP real do cliente.
- Configurar a exportação de logs de diagnóstico do WAF para um *workspace* do Log Analytics para auditoria detalhada das regras acionadas.
- Implementar políticas que exijam autenticação de múltiplos fatores (MFA) para todas as ações administrativas de alteração de configuração.
- Utilizar políticas de retenção de logs de auditoria (via Azure monitorar) para garantir que os registros não possam ser apagados prematuramente.

Information Disclosure

- Forçar o uso de TLS de ponta a ponta para que as chaves de acesso não sejam expostas em tráfego interno não criptografado.
- Obrigar o uso de TLS (Transport Layer Security) de ponta a ponta, criptografando o tráfego entre o balanceador de carga e os servidores de aplicação.
- Desabilitar mensagens de erro detalhadas e configurar páginas de erro genéricas no *Application Gateway* para ocultar informações do *backend*.
- Restringir estritamente as políticas de acesso do Cofre de Chaves do Azure (*Azure Key Vault*) apenas às Identidades Gerenciadas necessárias.
- Configurar o *backend* (servidores de aplicação) para remover cabeçalhos HTTP que revelem informações como versões de software ou tecnologias (`Server`, `X-Powered-By`).

Denial of Service

Gerado em: 2025-09-28 23:12:14

- Implementar a revalidação da cadeia de confiança dos certificados TLS (Transport Layer Security) do *backend* para autenticação mútua.
- Utilizar o serviço Azure DDoS Protection Standard (Proteção contra Ataques Distribuídos de Negação de Serviço) para mitigar ataques de volume na rede.
- Configurar regras de Limitação de Taxa (limitação de taxa) no WAF para restringir o número de requisições por cliente.
- Habilitar a funcionalidade de *autoscaling* (escalabilidade automática) no *Application Gateway* para lidar com picos de tráfego legítimos e ataques.
- Ajustar a sensibilidade e os intervalos dos *health probes* (sondas de saúde) para evitar a remoção indevida de servidores saudáveis.
- Configurar *timeouts* (*tempo limite*) de conexão e requisição reduzidos para liberar rapidamente recursos de sessões inativas ou lentas.

Elevation of Privilege

- Aplicar rigorosamente o princípio do menor privilégio usando o RBAC (Controle de Acesso Baseado em Função) para todas as contas administrativas.
- Garantir que as Identidades Gerenciadas utilizadas para comunicação tenham permissões estritamente limitadas (apenas leitura ou acesso específico a segredos).
- Auditar e restringir as ações permitidas nas funções RBAC para impedir a desativação de medidas de segurança (WAF, TLS) por administradores limitados.
- Utilizar *Azure Policy* para impor a ativação obrigatória de recursos de segurança (como o TLS de ponta a ponta) na criação do recurso.
- Monitorar logs de Atividade em busca de atribuições de função (RBAC) ou alterações de privilégio não autorizadas.

Amazon ElastiCache

Análise STRIDE:

Spoofing

- Um cliente mal-intencionado pode tentar se passar por um nó legítimo do cluster, explorando falhas nas Listas de Controle de Acesso (ACLs) do Redis ou nas configurações de grupos de segurança.
- Comprometimento de chaves de acesso ou credenciais utilizadas por aplicações para conexão com o serviço de *cache*, permitindo que entidades não autorizadas se apresentem como clientes válidos.
- Tentativas de ataques *man-in-the-middle* (intermediário) que buscam interceptar e falsificar a origem das requisições entre a aplicação e o nó de *cache*.
- Falta de mecanismos de autenticação forte, como a necessidade de senha de acesso (`AUTH`) configurada no motor Redis, permitindo conexões de clientes não autenticados que podem se passar por outros.
- Violação/Adulteração
- Injeção de dados corrompidos ou maliciosos no *cache* (*cache poisoning*), afetando a lógica da aplicação que consome essas informações.
- Modificação não autorizada dos parâmetros de configuração do cluster, como alterações nas políticas de despejo (evicção) ou no tamanho máximo de memória disponível (maxmemory).
- Alteração ou exclusão de dados de sessão críticos armazenados no *cache*, comprometendo a integridade da experiência do usuário ou de transações em curso.
- Adulteração das configurações de replicação ou *failover* (substituição), comprometendo a alta disponibilidade e a persistência dos dados.

Repudiation

- Falha na integração com serviços de log e auditoria do provedor de nuvem, impedindo o rastreamento de qual usuário ou serviço realizou uma ação crítica (como limpar o *cache* ou reiniciar o cluster).
- Ausência de logs detalhados para comandos administrativos executados contra o motor de *cache* (ex.: comandos `FLUSHALL` ou `CONFIG SET`).
- Incapacidade de correlacionar logs de aplicação com logs de acesso ao *cache*, dificultando a identificação do responsável por consultas ou modificações específicas.
- Divulgação de Informação

Gerado em: 2025-09-28 23:12:14

- Exposição de dados sensíveis (como tokens de sessão, credenciais ou informações de identificação pessoal) armazenados sem criptografia em repouso no disco de *backup* ou persistência.
- Conexões de clientes não utilizando TLS (Segurança da Camada de Transporte), o que expõe o tráfego de dados (incluindo chaves e valores) à interceptação na rede.
- Configuração inadequada das regras de firewall ou grupos de segurança, permitindo o acesso ao *cache* a partir de redes externas ou segmentos de rede não confiáveis.
- Armazenamento de informações em logs de depuração (*debug logs*) que podem inadvertidamente conter dados do cliente ou chaves de acesso do *cache*.

Denial of Service

- Exaustão da capacidade de memória do nó de *cache* devido a um alto volume de escrita, resultando em lentidão ou falhas na resposta (erros de OOM - falta de memória).
- Ataques de DDoS (Negação de Serviço Distribuído) que visam inundar o ponto de extremidade (endpoint) do *cache* com um número excessivo de requisições, tornando-o inacessível para tráfego legítimo.
- Consultas ou comandos lentos (ex.: operações de *scan* ou manipulação de grandes estruturas de dados) que monopolizam a *thread* principal do Redis, bloqueando outras operações.
- Configuração ineficaz da política de despejo (eviction policy), fazendo com que o *cache* remova dados necessários de forma agressiva durante picos de carga.
- Falhas de infraestrutura subjacente ou problemas de *networking* que isolam os nós do *cache* da aplicação consumidora.

Elevation of Privilege

- Exploração de vulnerabilidades não corrigidas no motor Redis ou Memcached que permitam a execução de comandos com privilégios de sistema operacional no nó subjacente.
- Configuração de Listas de Controle de Acesso (ACLs) que concede permissões de administrador (ALL) a clientes que deveriam ter acesso restrito (apenas leitura ou acesso limitado a chaves).
- Uso de comandos perigosos, como `DEBUG`, `MODULE LOAD` ou `CONFIG SET`, que podem ser desativados, mas se ativados, permitem a manipulação profunda e potencial escalção de privilégios.
- Falta de segregação de responsabilidades, onde o mesmo usuário ou serviço tem permissão para gerenciar a infraestrutura do *cache* e acessar dados sensíveis.

Mitigações sugeridas:

Spoofing

- Utilizar Identidades Gerenciadas para aplicações Azure para autenticação, evitando credenciais codificadas.
- Forçar o uso de TLS (Segurança da Camada de Transporte) para todas as conexões, prevenindo ataques intermediário (man-in-the-middle).
- Implementar o RBAC (Controle de Acesso Baseado em Função) do Azure para gerenciar quem pode visualizar ou rotacionar chaves de conexão.
- Configurar Grupos de Segurança de Rede (NSGs) para permitir acesso apenas de sub-redes confiáveis e isoladas.
- Habilitar o uso de senhas de acesso (AUTH) e garantir a rotação regular das chaves.
- Violação/Adulteração
- Usar ACLs (Listas de Controle de Acesso) do Redis (versão 6+) para definir permissões de escrita apenas para entidades específicas.
- Garantir que comandos de configuração do *cache* sejam realizados exclusivamente via API do Azure, protegida por RBAC.
- Aplicar validação e sanitização rigorosas no nível da aplicação para todos os dados antes que sejam armazenados no *cache*.
- Habilitar a persistência de dados (AOF ou RDB) no *cache* Premium ou Enterprise para recuperação de um estado válido.
- Proteger o ponto de extremidade (endpoint) administrativo do *cache* usando Azure Private Link ou VNet (Rede Virtual) Injection.

Repudiation

- Habilitar e configurar as Configurações de Diagnóstico para capturar e enviar logs de operação e métricas para o Azure monitorar.

Gerado em: 2025-09-28 23:12:14

- Garantir que logs de auditoria do plano de controle, como o Azure Activity Log, estejam ativados para ações administrativas.
- Utilizar Identidades Gerenciadas diferentes para serviços distintos para rastrear a origem exata da modificação.
- Habilitar o log de comandos lentos (Slow Command Log) do Redis para rastrear comandos destrutivos ou de alto custo.
- Implementar identificadores de rastreamento distribuído na aplicação para correlacionar transações com acessos ao *cache*.
- Divulgação de Informação
- Impor o uso exclusivo de TLS (Segurança da Camada de Transporte) 1.2 ou superior para criptografar dados em trânsito.
- Utilizar a integração com VNet (Rede Virtual) para isolar o *cache* de acesso via internet pública.
- Criptografar dados sensíveis no nível da aplicação antes de serem armazenados no *cache* (criptografia de dados em repouso).
- Revisar e restringir as regras de Grupos de Segurança de Rede (NSGs) para permitir acesso apenas na porta TLS configurada (ex.: 6380).
- Desabilitar ou configurar logs de depuração (*debug logs*) para nunca incluir valores de chaves ou dados de sessão.

Denial of Service

- Dimensionar o *cache* para uma camada (ex.: Premium ou Enterprise) que suporte alta disponibilidade e maior capacidade de memória.
- Configurar o Azure DDoS Protection (Proteção contra Negação de Serviço Distribuído) na VNet associada ao *cache*.
- Monitorar ativamente o uso de memória e CPU para acionar o escalonamento ou alertas antes da exaustão de recursos.
- Utilizar o agrupamento (*clustering*) para distribuir a carga de requisições e dados entre vários nós.
- Configurar uma política de despejo (*maxmemory-policy*) eficaz, como LRU (Least Recently Used), para gerenciar a memória.
- Implementar limites de taxa (limitação de taxa) na aplicação cliente para mitigar a inundação de requisições.

Elevation of Privilege

- Confiar no gerenciamento de segurança da plataforma Azure para aplicar *patches* e manter o motor do *cache* atualizado.
- Usar o RBAC (Controle de Acesso Baseado em Função) para segregar quem pode gerenciar o recurso de quem pode acessá-lo.
- Configurar ACLs (Listas de Controle de Acesso) do Redis para garantir que clientes de aplicação tenham apenas permissões de dados (não administrativas).
- Renomear ou desativar comandos perigosos de configuração no motor Redis, como `CONFIG` e `MODULE LOAD`.
- Assegurar que o serviço de *cache* esteja em uma rede isolada, inacessível a entidades com privilégios de sistema operacional.